SAVEETHA SCHOOL OF ENGINEERING

Course Code: ITA1439 Course Name: Ethical Hacking Slot: A

CO1 – ASSIGNMENT_1

Nature of Assignment: Individual Duration: 1 Week Total Marks: 50

Student Name	Register No.
Manoj Reddy	192311171

CO1: Apply the foundational concepts of ethical hacking, including the types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

Assignment Title: Design and Develop a Complete Ethical-Hacking Engagement Framework for a University's Authorized Security-Assessment Programme.

Summary of the solution

This document solves all eleven tasks of the assignment with one integrated design, the **University Ethical-Hacking Engagement Framework (UEHEF)**. The framework answers who authorizes a test, what is in scope, which laws apply, which attackers are modelled, what conduct is acceptable, how an isolated lab is used and how findings are disclosed. Every major decision is supported by a table, a figure or a test result. The tests were executed with small Python models of the decision rules (no live exploitation, no network scanning); the scalability results come from a seeded simulation whose assumptions are stated in Task 10. Legal and disclosure reference points were taken from public sources, including the Anthropic pages linked from claude.com, and are listed in the references.

Notes: the university is referred to as "the University"; engagement IDs, IP addresses (except the lab range 192.168.56.0/24), dates and names of roles are illustrative. This is a design exercise, not legal advice.

Task	Topic	Marks
1	Enquiry questions, requirements, blueprint and design criteria	4
2	Hacker threat model and classification	4
3	Ethics and code-of-conduct module	4
4	Legal-compliance mapping (IT Act 2000, DPDP Act, CFAA)	4
5	Scope and rules-of-engagement document	4
6	Authorization and disclosure layer	5
7	Isolated ethical-hacking lab	5
8	Reusable document library	5
9	Integration, walkthrough, test and refinement	5
10	Scalability and governance evaluation	5

Task	Topic	Marks
11	Defence under a changed requirement	5
Total		50

TASK 1 – Formulate the Enquiry and Framework Blueprint (4 Marks)

The scenario is converted below into formal engagement-governance requirements, a blueprint that shows how the components cooperate, a set of enquiry questions that the framework must answer, and a set of design criteria that are used as acceptance criteria in Task 11. The framework is named **UEHEF** (University Ethical-Hacking Engagement Framework). The word "University" refers to the institution in the scenario; all identifiers, addresses and dates used are illustrative.

1.1 Governance requirements derived from the scenario

ID	Requirement (the framework shall …)	Scenario source	Component
R1	require a signed written authorization from the system owner and the CISO before any test action is performed	"unauthorized access"	C1
R2	list every in-scope asset explicitly (ID, IP, owner); anything not listed is out of scope by default	"unclear scope"	C2
R3	map each engagement activity to the applicable law (IT Act 2000, DPDP Act 2023, CERT-In directions) and compare with an international law (CFAA)	"legal exposure"	C3
R4	apply a data-protection check whenever a target holds personal data	"systems that hold personal data"	C3, C1
R5	protect live systems through testing windows, rate limits, prohibited techniques and a kill-switch	"damage to live systems"	C2, C5
R6	accept requests from any department through one uniform intake process	"requested by different departments"	C1
R7	vet external testers and bind them by NDA and a code of conduct	"internal staff or external testers"	C1, C5
R8	provide an isolated lab for hands-on practice before live testing	"isolated-lab level"	C6
R9	disclose findings only through a defined, timed, coordinated process	"uncoordinated disclosure"	C7
R10	scale from 20 systems / 50 staff to the whole university and third-party assessors by configuration, not redesign	"remain usable as the programme grows"	All
R11	record every approval, status change and decision in an auditable log	"governance decisions … justify"	C1, C8
R12	separate the questions: authorized? legal? appropriate?	"clearly distinguish"	C1, C3, C5

ID	Requirement (the framework shall …)	Scenario source	Component
R13	model the attackers relevant to the university so that tests are realistic and relevant	"types of hackers"	C4
R14	perform no live exploitation within this assignment (design, documentation and lab level only)	"No live exploitation is performed"	All

Systems in scope (initial programme: 20 systems)

Service group	Systems (register IDs)	Count	Hold personal data
Student portal	SYS-01 web front-end, SYS-02 application server, SYS-03 student-records database, SYS-04 single sign-on	4	4 (all)
Learning-management system (LMS)	SYS-05 web front-end, SYS-06 application server, SYS-07 database, SYS-08 content store, SYS-09 plugin/integration server (vendor-hosted)	5	4 (all except SYS-09)
E-mail service	SYS-10 mail gateway, SYS-11 mailbox server, SYS-12 webmail, SYS-13 mail archive	4	4 (all)
Campus network	SYS-14 core switch, SYS-15 distribution switches, SYS-16 WLAN controller, SYS-17 perimeter firewall, SYS-18 DNS/DHCP, SYS-19 VPN gateway, SYS-20 RADIUS/802.1X	7	1 (SYS-20)
Total		20	13

Explicitly out of scope (named in the register so that requests touching them can be detected): payroll/finance ERP (10.30.1.0/24), health-centre records (10.30.2.0/24), research HPC cluster (10.30.3.0/24), student hostel/BYOD networks (10.40.0.0/16), the third-party payment gateway and library SaaS, and the personal devices of students and staff.

Stakeholders

Stakeholder	Role in the programme	Main interest
Vice-Chancellor / Registrar	Ultimate accountability; receives escalations	Reputation, legal exposure
CISO	Co-signs every authorization; chairs the Governance Board	Security posture, control over testing
Ethical-Hacking Governance Team (us)	Designs, runs and audits the framework	Consistent, defensible decisions
System owners (Deans, HoDs, IT heads)	Request tests, sign for their systems, fix findings	Service availability, timely fixes
Data Protection Officer (DPO)	Reviews tests that touch personal data; assesses incidents	DPDP compliance, data-subject protection

Stakeholder	Role in the programme	Main interest
Internal testers / IT staff (about 50 staff)	Perform in-house tests, operate the lab	Clear rules, protection when acting in good faith
External assessors	Perform third-party tests under contract	Clear scope, safe harbour, payment
Students and staff (data subjects)	Their data sits in the portal, LMS and e-mail	Privacy and continuity of service
Legal counsel; CERT-In; software vendors	Legal advice; national incident coordination; patch owners	Lawful, coordinated handling

Expected activities and constraints

- **Activities:** passive reconnaissance, port and vulnerability scanning, configuration review, web-application testing with test accounts, wireless and network-segmentation review, password-policy audit, lab rehearsal, reporting, retesting, disclosure and closure.
- **Constraints:** (i) law – IT Act 2000, DPDP Act 2023, CERT-In directions; (ii) live-service availability, especially during admissions and examinations; (iii) personal data of students and staff; (iv) limited staff (about 50) and a single CISO office; (v) growth to external assessors; (vi) no live exploitation inside this assignment.

1.2 Framework blueprint

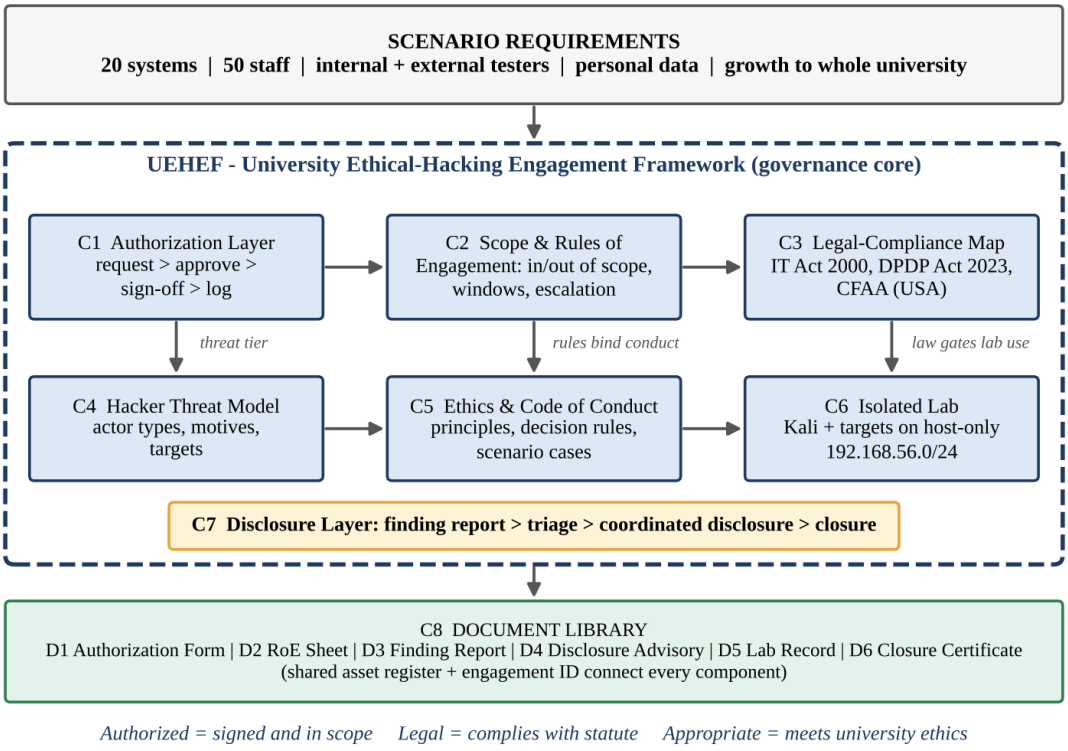


Figure 1: Requirements-to-governance blueprint of UEHEF (components C1–C8)

Figure 1 shows the cooperation. The **engagement record** (engagement ID, targets, window, signers, DPIA reference) is the spine that all components read and write. The interfaces between components are listed below; each is implemented and tested in Tasks 5–9.

From → To	What is passed	Effect
C4 Threat model → C1/C2	Threat tier and likely attack paths	Decides the risk tier (low / high / external) and the permitted techniques
C3 Legal map → C1	Personal-data flag and DPIA reference requirement	Authorization is put on HOLD if a PD system has no DPIA reference
C2 RoE → C1	Targets, window, techniques	Authorization checks A5/A8/A10 reject out-of-scope or prohibited requests
C1 Authorization → C6 Lab	Lab authorization record	Only authorized testers receive lab access and the lab RoE
C5 Ethics → all	Decision rules and stop-and-ask checks	Every tester action is ACCEPTABLE, BORDERLINE or UNACCEPTABLE
C6 Lab → C7 Disclosure	Lab-validated finding (D3 JSON)	Starts the disclosure clock; severity routes the decision
C7 Disclosure → C3 Legal	Personal-data-exposed flag	Triggers DPO notification and the 72-hour breach clock where applicable
C8 Library → all	Documents D1–D6 with shared fields	Same engagement ID and asset IDs in every document

1.3 Enquiry questions the framework must answer

#	Enquiry question	Answered by
Q1	Who authorizes a test, in what form, and how is the authorization proved and recorded?	C1, D1 (Tasks 5, 6)
Q2	What exactly is in scope, and how is an out-of-scope request detected?	C2, D2 (Task 5)
Q3	Which laws apply, what are the penalties, and which apply when personal data is touched?	C3 (Task 4)
Q4	Which types of attackers are relevant, and how is an actor classified consistently?	C4 (Task 2)
Q5	What conduct is acceptable, borderline or unacceptable during an engagement?	C5 (Task 3)
Q6	How, when and by whom are findings disclosed, and when is full disclosure justified?	C7, D3, D4 (Task 6)
Q7	Where is hands-on testing practised safely and how is containment shown?	C6, D5 (Task 7)
Q8	Does the framework still work for the whole university and under changed requirements?	Tasks 10 and 11

1.4 Design criteria (used as acceptance criteria)

ID	Design criterion	Measurable acceptance test	Checked in
DC1	Authorization completeness – no test action without a valid signed D1	All authorization test cases give the expected decision (17 cases)	Tasks 8, 9
DC2	Scope precision – no out-of-scope target accepted	All scope-boundary cases correct (7 cases) including boundary times	Tasks 5, 9
DC3	Legal traceability – every legal requirement has at least one control	Each row of the legal table links to a control and a test	Task 4
DC4	Containment – lab has no route to production or the Internet	Connectivity verification: negative tests all fail as expected	Task 7
DC5	Timeliness – disclosure windows are defined and overdue findings are escalated	Overdue and 80 % cases trigger actions in the disclosure tests	Tasks 6, 9, 11
DC6	Scalability – approval turnaround stays near one working day at university scale	Mean approval time of the refined design at large scale is no more than 1 working day	Task 10
DC7	Reusability – at least four documents with defaults and validation	Document library tests pass for valid, boundary and invalid entries	Task 8
DC8	Adaptability – a changed requirement is absorbed by modifying, not replacing, most components	Majority of components retained or modified in the revised design	Task 11

1.5 Rationale

Three governance options were compared: (a) leave each department to arrange its own tests (fast, but this is exactly the unstructured approach the team fears); (b) a single policy document (simple, but it gives no mechanism to check scope or to log decisions); and (c) a layered framework in which a small set of components share one engagement record and a document library. Option (c) is chosen because it is the only option that satisfies R10 and R11 together: new departments or external testers are added by creating new records, not by changing the rules. Its cost is more initial design effort and a small amount of administration per engagement, which Task 10 measures and Task 11 reduces further.

TASK 2 – Design a Hacker Threat Model and Classification (4 Marks)

2.1 Classification criteria and naming

An actor is described by four attributes: (A) **authorization** – is there written permission for the activity; (B) **intent** – benevolent, curiosity, ideological, financial, espionage/strategic, or grievance; (C) **position** – external, internal (holds a university account or privilege) or third-party; (D) **capability** – 1 (uses ready-made tools) to 5 (well-funded, custom tooling). The ordered rules below are applied top to bottom and the first rule that fits decides the class. This makes classification repeatable between reviewers.

Rule	Condition	Class
CR1	Written authorization exists AND the conduct stays inside the authorized scope	White-hat (WH)
CR2	Actor holds university-granted access or privilege AND misuses it with malicious or grossly negligent intent	Insider (IN)
CR3	Actor is government-backed or equivalently resourced, with persistent strategic aims (espionage, research theft)	State-sponsored (SS)
CR4	Motive is political or social, and publicity or disruption is the goal	Hacktivist (HK)
CR5	No authorization AND no evidence of malicious intent AND the actor discloses the issue	Grey-hat (GH)
CR6	No authorization, capability 1–2, uses tools or scripts without understanding them	Script kiddie (SK)
CR7	No authorization AND financial gain, damage or theft is the intent (default for unauthorized and harmful)	Black-hat (BH)

Naming convention: CLASS-ORIGIN-CAPABILITY, for example **GH-INT-2** means a grey-hat actor from inside the university community with capability 2; **BH-EXT-4** is an external criminal with capability 4; **WH-3P-3** is a third-party assessor. ORIGIN is EXT, INT or 3P. A tie between two rules is resolved by the rule with the lower number, and any override must be recorded with a reason.

2.2 Threat model and mapping table

Class (code)	Motivation	Typical capability	Likely university targets	Primary control
White-hat (WH)	Improve security; paid or assigned	3–5	Systems named in the signed D1/D2	C1, C2, C5
Black-hat (BH)	Money, ransom, resale of student data and credentials	3–5	Student records DB (SYS-03), mail (SYS-10 to SYS-13), SSO (SYS-04)	Patching, MFA, monitoring

Class (code)	Motivation	Typical capability	Likely university targets	Primary control
Grey-hat (GH)	Curiosity, reputation, "helping" without asking	2–4	Public web front-ends (SYS-01, SYS-05, SYS-12)	Disclosure channel, student-tester roster
Script kiddie (SK)	Fun, bragging, copying tutorials	1–2	Login pages, exposed services, WLAN	Rate limiting, hardening, WAF
Hacktivist (HK)	Political or social protest	2–4	Public web site, LMS front-end (defacement, DoS)	DDoS protection, incident plan
Malicious insider (IN)	Grievance, grade or fee manipulation, data sale	2–4 (with valid access)	SYS-03, SYS-07 (marks, records), RADIUS, mail archive	Least privilege, logging, two-person rule
State-sponsored (SS)	Espionage, research and IP theft	4–5	Research data, staff mail, VPN gateway, SSO	Network segmentation, threat intelligence

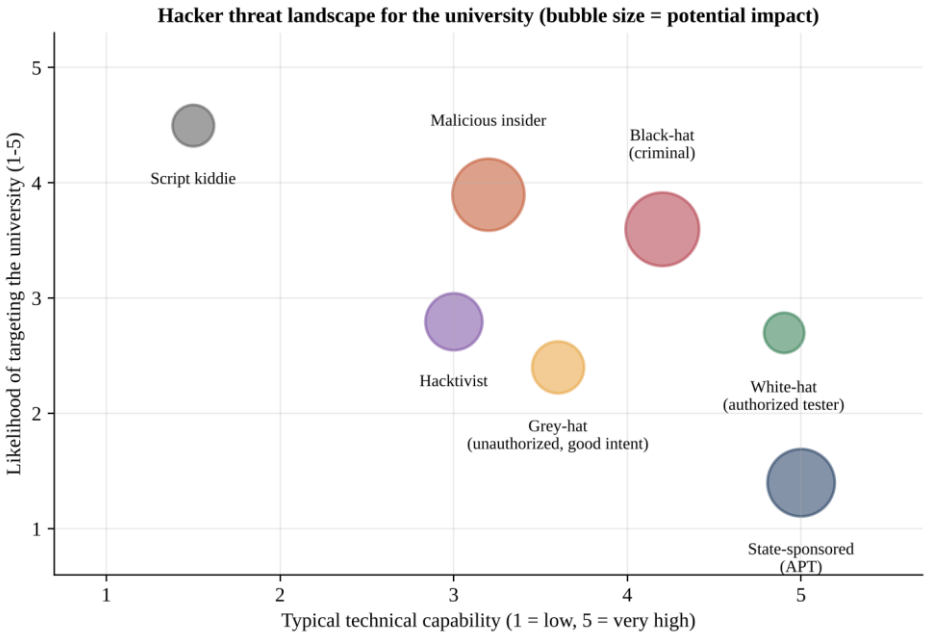


Figure 2: Threat landscape – capability against likelihood of targeting (scores are the team's qualitative judgement)

The scores in Figure 2 are qualitative (1–5) and reflect the team's judgement for a university with open-access services and a large population of students and staff. The most likely actors are script kiddies and malicious insiders; the highest-impact actors are black-hat criminals and insiders with privileged access. State-sponsored actors are unlikely but would have high impact on research data, so they are covered by general hardening rather than by specific tests in the initial 20 systems.

Consistency test of the criteria

Sample actor	Rule that fires	Class and code
Consultant with signed scope of SYS-05 to SYS-09 scans only those systems	CR1	White-hat WH-3P-3
Same consultant scans the payroll network as well	CR1 fails (out of scope); CR2 not met; CR5 not met (no disclosure); CR7 if harmful intent is shown	Unauthorized actor – classified by intent; recorded as a conduct breach (Task 3)
Clerk with database access sells 300 student records	CR2	Insider IN-INT-2
Group defaces the university site with a protest slogan	CR4	Hacktivist HK-EXT-3
Teenager runs a downloaded exploit script against the login page	CR6	Script kiddie SK-EXT-1
Persistent intrusion into research server, nothing monetised, advanced tooling	CR3	State-sponsored SS-EXT-5

2.3 Borderline actor: two alternative classifications

Case. A final-year student runs a port scan and a simple SQL-injection test on the LMS out of curiosity, reads five records to confirm that the flaw is real, deletes them, and the next day e-mails the Dean a description and offers to help. No payment is asked and no data is published. There is no written authorization.

Alternative	Criteria for	Criteria against	Decision
Alt-1: Black-hat (BH-INT-2)	Unauthorized access to a system with personal data; records were read (IT Act s.43/s.66 conduct)	No intent to harm or profit (CR7 requires it); data deleted and the flaw disclosed	Rejected
Alt-2: White-hat (WH-INT-2)	Good intent; responsible disclosure; no harm	CR1 requires prior written authorization; permission cannot be given afterwards, so the first rule fails	Rejected
Alt-3: Insider (IN-INT-2)	Holds a student account of the university	CR2 needs malicious or grossly negligent misuse of granted privilege; intent here was not malicious	Rejected
Alt-4: Grey-hat (GH-INT-2)	No authorization AND no malicious intent AND discloses (all three parts of CR5)	Legal exposure remains (access was unauthorized)	Selected

Justified final classification: GH-INT-2 (grey-hat, internal community, capability 2). Classification describes the actor, not the legal outcome: the access was still unauthorized, so

the incident is recorded and the university may take disciplinary action, but the response is proportionate (acknowledge the report, fix the flaw, brief the student, offer an invitation to the authorized student-tester roster). Treating the student as a black-hat would discourage future reports and push curious people towards silence; treating the student as a white-hat would suggest that permission is optional. This is the main reason for putting authorization first (CR1) in the rule order.

TASK 3 – Create an Ethics and Code-of-Conduct Module (4 Marks)

3.1 Ethical principles

Principle	Rule of behaviour	Evidence produced
P1 Written authorization	No scan, login or test without a signed D1 that covers the action	Engagement ID in every log and report
P2 Agreed scope	Touch only listed assets, inside the window, using permitted techniques	Scope allow-list check (S1–S5)
P3 Confidentiality	Findings, credentials and data are shared only with named recipients (need to know)	NDA, restricted evidence store
P4 Integrity	Never alter or delete logs, evidence or data; report results as they are	Hash-chained log, tool output kept
P5 Avoid harm	Use the least intrusive method that proves the point; stop if service degrades	Rate limits, kill-switch, HALT message
P6 Honest reporting	Report all findings including own mistakes; no exaggeration or hiding	D3 report, incident note for mistakes
P7 Privacy by minimisation	See, copy and keep as little personal data as possible; redact evidence	Evidence redaction rule F5
P8 Lawfulness and professionalism	Follow the law, the contract and the code; no payment demands or threats; declare conflicts of interest	Signed code acknowledgement

3.2 Rules and checks that prevent or detect unethical action

Stop-and-ask check. Before each phase and whenever something unexpected happens, the tester must answer five questions: (1) Is there a signed D1 for this? (2) Is the target on the allow-list? (3) Is it inside the window? (4) Is the technique permitted and the impact the smallest needed? (5) Will any personal data be seen or kept? Any "No" or "Not sure" means **stop and escalate** – never "try and see".

Type	Control	What it catches
Preventive	Dual sign-off (system owner + CISO); scope allow-list; signed code acknowledgement; tool profiles with rate limits; two-person rule for exploitation steps; kill-switch word HALT	Unauthorized, out-of-scope or damaging actions
Preventive	Evidence redaction and no-copy rule for personal data; no payment or threats clause	Privacy breaches, extortion
Detective	Hash-chained engagement log; command history captured; Governance Team reviews logs within 48 hours; alert on traffic to any address outside the allow-list	Tampering, scope drift, hidden probes
Corrective	Immediate stop; incident note within 1 hour; owner and DPO informed; disciplinary or contractual action	Repeat breaches

Decision rule. Each action is evaluated by a rule that returns ACCEPTABLE, BORDERLINE or UNACCEPTABLE:

```
UNACCEPTABLE  if  no written authorization  OR  target out of scope  OR  prohibited technique
            OR  personal data copied/retained  OR  logs/evidence tampered  OR  payment/threat demanded
BORDERLINE    if  scope unclear  OR  window overrun  OR  personal data seen incidentally
            OR  written permission needed (for example publishing a finding)
ACCEPTABLE    otherwise
Response:  ACCEPTABLE -> proceed and log | BORDERLINE -> pause, record, ask owner/CISO | UNACCEPTABLE -
> stop, report within 1 hour
```

3.3 Scenario cases

Twelve cases (four acceptable, four borderline, four unacceptable) were encoded as inputs to the decision rule and run (conduct.py). The result column is the output of that run.

ID	Case	Expected	Rule output	Response of the code of conduct
A1	Rate-limited vulnerability scan of SYS-09 at 01:00, inside window	ACCEPTABLE	ACCEPTABLE	Proceed; entry written to the log – reason: all checks pass
A2	Logs in once with a default password on an in-scope switch, screenshots the prompt only, logs it	ACCEPTABLE	ACCEPTABLE	Proceed; entry written to the log – reason: all checks pass
A3	Reports a critical flaw to the CISO the same day instead of waiting for the final report	ACCEPTABLE	ACCEPTABLE	Proceed; entry written to the log – reason: all checks pass
A4	Asks the Governance Team before touching a newly discovered in-scope sub-service	ACCEPTABLE	ACCEPTABLE	Proceed; entry written to the log – reason: all checks pass
B1	Scan shows host 10.20.2.15, same subnet but not in the register; tester wants to continue	BORDERLINE	BORDERLINE	Pause; record; ask owner / CISO / DPO before continuing – reason: scope unclear
B2	Error page displays a student's name and roll number during an authorized test	BORDERLINE	BORDERLINE	Pause; record; ask owner / CISO / DPO before continuing – reason: personal data seen incidentally
B3	Slow scan overruns the window by 40 minutes	BORDERLINE	BORDERLINE	Pause; record; ask owner / CISO / DPO before continuing – reason: window overrun
B4	External tester wants to use the anonymised finding in a conference talk	BORDERLINE	BORDERLINE	Pause; record; ask owner / CISO / DPO before continuing – reason: needs written permission
U1	Pivots from SYS-09 into the payroll ERP because the credentials also work	UNACCEPTABLE	UNACCEPTABLE	Stop; report within 1 hour; review for disciplinary or legal action – reason: target out of scope

ID	Case	Expected	Rule output	Response of the code of conduct
U2	Downloads 2,000 student records 'as proof'	UNACCEPTABLE	UNACCEPTABLE	Stop; report within 1 hour; review for disciplinary or legal action – reason: prohibited technique; personal data copied/retained
U3	Offers not to publish a finding if paid	UNACCEPTABLE	UNACCEPTABLE	Stop; report within 1 hour; review for disciplinary or legal action – reason: payment/threat demanded
U4	Deletes log lines showing an out-of-scope probe	UNACCEPTABLE	UNACCEPTABLE	Stop; report within 1 hour; review for disciplinary or legal action – reason: logs/evidence tampered

Evidence that the rules separate acceptable from unacceptable actions: all 12 of 12 cases returned the expected class. The cases differ by a single input, which shows that the boundary is sharp: for example B2 (personal data seen) is BORDERLINE, whereas U2 (personal data copied) is UNACCEPTABLE.

3.4 How the module preserves trust and keeps engagements lawful and professional

- **Trust of the university community:** students and staff are told that tests are authorized, logged and bounded by a code of conduct; personal data is minimised and redacted.
- **Trust of testers:** a tester who stays inside the signed scope is protected by the university's written authorization; a tester who is unsure is told to stop and ask, not blamed for asking.
- **Lawfulness:** the rule "no written authorization means unacceptable" mirrors the legal position that unauthorized access is an offence (Task 4), and the ban on copying personal data supports the data-protection duties.
- **Professionalism:** honest reporting, no threats or payment demands (this matches the industry practice in Anthropic's responsible-disclosure policy, which also forbids demanding payment and retaining data), and a documented response for every outcome.

TASK 4 – Construct a Legal-Compliance Mapping (4 Marks)

4.1 Legal landscape

Three layers of law apply to an engagement in India. (1) The **Information Technology Act, 2000** (as amended in 2008) creates civil liability and criminal offences for unauthorized access and damage, and gives CERT-In (Section 70B) its role. (2) The **Digital Personal Data Protection Act, 2023** and the DPDP Rules, 2025 (notified in November 2025) regulate the processing of digital personal data; secondary sources report that the main obligations, penalties and the omission of Section 43A of the IT Act commence about 18 months after notification, i.e. around May 2027, so on the date of this assignment (1 November 2026) Section 43A and the older security rules are still the operating regime and DPDP duties are being prepared for. (3) The **CERT-In Directions of 28 April 2022** require specified cyber incidents to be reported within 6 hours of noticing them. For comparison, the **Computer Fraud and Abuse Act (CFAA, 18 U.S.C. §1030)** of the United States is used as the international benchmark; it matters directly if an external assessor, a cloud host or an affected person has a United States connection.

Key legal insight for the framework: neither statute contains a general safe harbour for ethical hackers. The only thing that makes security testing lawful is **authorization from the person entitled to give it**. This is why authorization (C1) is the first and strictest control of the framework. This mapping is a design aid and not legal advice; it must be confirmed by the university's legal counsel.

4.2 Offences, obligations and penalties – India (IT Act, DPDP Act, CERT-In)

Provision	Offence / obligation	Penalty or consequence	Relevance to an engagement
IT Act s.43(a)–(j)	Access, download, copy, introduce virus, damage, disrupt, deny access, alter or destroy data, without permission of the owner or person in charge	Civil: compensation to the person affected (adjudicating officer handles claims up to ₹5 crore; larger claims go to a civil court)	Core risk for testers: any act outside the signed scope
s.43A	Body corporate possessing sensitive personal data fails to keep reasonable security practices	Compensation to the affected person; no fixed upper limit. To be omitted when DPDP provisions commence (about May 2027)	University is the body corporate for student data; a careless test that leaks data can trigger it
s.66	Dishonest or fraudulent act covered by s.43	Imprisonment up to 3 years, or fine up to ₹5 lakh, or both	Criminal liability if intent is dishonest or fraudulent
s.66B / 66C / 66D	Receiving stolen computer resource; identity theft (using another's password); cheating by personation	Up to 3 years and/or fine up to ₹1 lakh each	Using real student or staff credentials in a test
s.66F	Cyber-terrorism	Imprisonment which may extend to life	Not expected; shows why attacks on critical systems are never in scope

Provision	Offence / obligation	Penalty or consequence	Relevance to an engagement
s.70	Access to a notified "protected system"	Up to 10 years and fine	Check that no register asset has been notified; if so, NCIIPC clearance is needed
s.72	Breach of confidentiality and privacy by a person empowered under the Act who secures access to records and discloses them without consent	Up to 2 years, or fine up to ₹1 lakh, or both	Disclosure of records seen during a test
s.72A	Disclosure of personal information obtained under a lawful contract, in breach of that contract or without consent	Up to 3 years, or fine up to ₹5 lakh, or both	External assessors who pass on data obtained under contract
s.70B and CERT-In Directions 2022	Report listed cyber incidents to CERT-In within 6 hours of noticing; keep logs (180 days) and synchronise clocks; keep a point of contact	Failure to comply: punishable under s.70B(7) (imprisonment up to 1 year or fine up to ₹1 lakh, or both)	Decides whether a test event is a mere finding or a reportable incident
s.85	Offences by companies: persons in charge are liable unless they show lack of knowledge or due diligence	Persons responsible are deemed guilty	Board-level sign-off and due-diligence records protect officers
DPDP Act 2023, s.8(5)–(6) and Rules	Data fiduciary must take reasonable security safeguards; must inform the Data Protection Board and each affected person of a personal-data breach (detailed report to the Board within 72 hours under the Rules)	Penalty Schedule: up to ₹250 crore for failure to take reasonable security safeguards; up to ₹200 crore for failure to give breach notice	University = data fiduciary; external tester = data processor, needs a contract (s.8(2))

4.3 International comparison – CFAA (United States)

Provision	Offence	Maximum penalty (first offence)	Comment
§1030(a)(2)	Intentionally accessing a computer without authorization or exceeding authorized access and obtaining information	Up to 1 year; up to 5 years if for commercial gain, in furtherance of another crime or value above US$5,000; up to 10 years for repeat offences	Closest to IT Act s.43(a)/(b) and s.66
§1030(a)(5)(A)	Knowingly causing transmission of a program or command that intentionally damages a protected computer	Up to 10 years	Closest to s.43(c)–(e) (virus, damage, disruption)
§1030(a)(5)(B)/(C)	Reckless damage / damage and loss through unauthorized access	Up to 5 years / up to 1 year	Damage without intent is still punishable
§1030(a)(7)	Threatening to damage or reveal data to extort money or value	Up to 5 years	Maps to the code-of-conduct rule against threats and payment demands

Provision	Offence	Maximum penalty (first offence)	Comment
§1030(g)	Civil action by a person suffering damage or loss (generally at least US$5,000 loss)	Compensatory damages, injunctive relief	Comparable to compensation under s.43

Aspect	IT Act 2000 (India)	CFAA (USA)
Trigger term	"Without permission of the owner or any other person who is in charge"	"Without authorization" or "exceeds authorized access"
Civil + criminal	Civil compensation (s.43) and criminal punishment (s.66)	Criminal (§1030(a)–(c)) and civil action (§1030(g))
Safe harbour for researchers	None in the statute; authorization is the only defence in practice	None in the statute; since May 2022 the DOJ charging policy tells prosecutors not to charge good-faith security research, but this is policy and does not bind civil plaintiffs or other prosecutors
Contract-only limits	Permission may be limited by the owner's terms	After Van Buren v. United States (2021) and the DOJ policy, breach of a policy or contract alone is generally not "exceeding authorized access", unless access to the area is barred in all circumstances
Reach beyond the country	s.75 applies to offences outside India that involve a computer in India	Applies to any "protected computer", including computers outside the US that affect US commerce
Data protection	s.43A / DPDP Act 2023 (separate statute)	No general privacy rule; sector laws and state laws apply

4.4 Legal requirement → framework control

ID	Legal requirement	Control in the framework	Evidence
L1	Access only with permission of the owner (s.43(a), s.66; CFAA (a)(2))	C1 dual-signed D1 with check A1–A6; C2 allow-list and runtime check S1–S5	Auth tests I1–I3; scope tests S-invalid
L2	No copying, altering, destroying or introducing malicious code (s.43(b),(c),(i))	Prohibited techniques: data exfiltration, persistence, real-account use; malware only inside the lab	Auth test I5; conduct case U2
L3	No disruption or denial of access (s.43(e),(f); CFAA (a)(5))	DoS prohibited; rate limits; testing window 23:00–05:00; exam blackout; kill-switch	Auth tests I5, R2, R3; scope test 05:00
L4	Reasonable security safeguards for personal data (s.43A; DPDP s.8(5))	DPIA reference for PD targets (A7); evidence redaction (F5); restricted evidence store	Auth test I6; finding test I3
L5	Breach intimation (DPDP s.8(6); 72-hour detailed report)	Breach lane in disclosure: DPO informed at once, 72-hour clock when data is actually compromised	Disclosure test F6
L6	Report listed incidents to CERT-In within 6 hours	Triage step separates a "finding" from an "incident"; incident triggers CERT-In contact within 6 hours	Task 9 walkthrough, day 13

ID	Legal requirement	Control in the framework	Evidence
L7	Confidentiality of data obtained (s.72, s.72A)	NDA for every tester (A6); need-to-know distribution of D3	Auth test I4
L8	Corporate accountability (s.85)	CISO and system-owner signatures; Board approval for high-risk and full disclosure	Auth test I1; disclosure rule D5
L9	CFAA exposure for US-linked assets or assessors	Third-party and cloud systems are out of scope unless written consent is attached (A9); assessor agreement D7	Auth test R1
L10	No extortion (CFAA (a)(7); Indian criminal law)	Code of conduct: payment demand or threat is UNACCEPTABLE	Conduct case U3
L11	Protected systems (s.70)	Register check before approval: any notified asset needs NCIIPC clearance	Intake check (step 2)

4.5 Decision: which laws apply when a test touches personal data

Law	Applies?	Reason	Decision for the framework
IT Act 2000 (s.43, 66, 72, 70B)	Yes, always	Computers are in India and owned by an Indian institution	Authorization + scope + logging are mandatory for every engagement
CERT-In Directions 2022	Yes, if a listed incident is noticed	Applies to service providers and bodies corporate	Incident triage step with a 6-hour reporting clock
s.43A and the older security rules	Yes, until DPDP commencement	Still in force on 1 Nov 2026	Treat PD systems as requiring reasonable security practices during testing
DPDP Act 2023 and Rules 2025	Yes in design; legally binding on the main duties from about May 2027	University is a data fiduciary for 13 of 20 systems; testers handle data as processors	Adopt DPDP-grade controls now (DPIA reference, minimisation, processor clause, 72-hour breach lane). Cheaper than redesign later
CFAA (USA)	Not automatically; conditional	Applies only where an asset, assessor or affected person has a US nexus	Use as a benchmark; exclude US-hosted or third-party systems unless consent is attached; add a CFAA clause to D7

Conclusion. For a test that touches personal data the university must satisfy the IT Act (authorization, no damage, confidentiality), the CERT-In incident rules, and the data-protection regime (s.43A today, DPDP from its commencement). The CFAA is not binding on a purely Indian test, but it justifies the third-party consent rule and gives a model of good-faith research that the university can copy in its own safe-harbour wording. The framework therefore places the legal gate (step 4 of the workflow) **before** sign-off: no authorization is approved for a personal-data system without a DPIA reference.

TASK 5 – Create a Scope and Rules-of-Engagement Document (4 Marks)

5.1 Rules-of-Engagement document (D2) – template filled for ENG-2026-007

Section	Content
1 Identity	Engagement ID ENG-2026-007; title "Pre-upgrade assessment of the LMS"; requester: Dean, School of Computing; system owner: LMS service owner; version 1.1
2 Objective	Identify exploitable weaknesses in the LMS before the planned upgrade; no exploitation beyond proof of existence
3 In scope	SYS-05 (10.20.2.10), SYS-06 (10.20.2.11), SYS-09 (10.20.2.14, vendor-hosted; written consent VENDOR-CONSENT-117)
4 Out of scope	SYS-07 and SYS-08 (databases and content store, tested only through the web tier), payroll ERP 10.30.1.0/24, health centre 10.30.2.0/24, HPC 10.30.3.0/24, hostel/BYOD 10.40.0.0/16, payment gateway, any address not in the register, personal devices, social engineering, physical access
5 Testing window	9 Nov 2026 to 22 Nov 2026, daily 23:00–05:00 IST; no testing on days in the examination blackout (14–30 Dec 2026) or during admission-result days
6 Permitted techniques	Passive reconnaissance; port scan (max 100 packets per second); authenticated and unauthenticated vulnerability scan; web testing with the two supplied test accounts; configuration review; minimal proof-of-concept that stops at proof of existence
7 Prohibited techniques	Denial of service; social engineering; physical intrusion; data exfiltration; persistence or backdoors; lateral movement outside scope; use of real student or staff accounts; password cracking outside the lab
8 Data handling	Personal data must not be copied. Screenshots are redacted. Evidence is kept in the encrypted evidence store for 12 months and then destroyed. DPIA reference DPIA-2026-003
9 Communication	Daily start and end message to the Governance Team; findings of Critical or High severity reported to the CISO within 4 hours of validation
10 Incident during test	Service slowdown, unexpected data, scope doubt: send HALT, stop, record, call the escalation contact below
11 Reporting	D3 finding report (JSON and PDF) within 3 working days of the end of testing
12 Sign-off	System owner, CISO, DPO (for PD systems), tester lead. Each signature carries name, role, date and the SHA-256 of this document

Escalation paths

Level	Trigger	Contact	Response time
L1	Scope doubt, window overrun, tool error	Tester lead → Governance Team on-call	15 minutes
L2	Service degradation; personal data seen; Critical or High finding	CISO (and DPO for personal data)	30 minutes (4 hours for reporting a finding)

Level	Trigger	Contact	Response time
L3	Outage of a live service; suspected real attack in progress; reportable incident	CISO → Registrar / Vice-Chancellor's office; CERT-In contact	Immediate; CERT-In report within 6 hours
Emergency	Anyone sends HALT	All testing stops at once	Immediate

5.2 Rules for recording and verifying written authorization

Rule	Statement
AV1	Every engagement receives a unique ID in the form ENG-YYYY-NNN; verbal or e-mail-only approval is invalid.
AV2	Two signatures are mandatory: the system owner and the CISO; a third signature (DPO) is mandatory if any target holds personal data.
AV3	Signatory authority follows the matrix below; a signature by a person who is not on the matrix is invalid.
AV4	The signed PDF is hashed (SHA-256) and the hash is stored in the engagement register; any later change shows as a hash mismatch.
AV5	For external requesters, the CISO office verifies the request by a call-back to a known number (guards against forged requests).
AV6	Authorization is valid only for the stated dates (maximum 30 days; longer needs Board approval) and cannot be back-dated.
AV7	Authorization can be revoked at once by the CISO; the register status becomes REVOKED and testers are told by phone and e-mail.
AV8	Testers carry (or can display) the authorization ID; the SOC and network team receive the target list and window in advance.

System class	System owner who signs	Second signature	Third signature
Student portal, student records (SYS-01 to 04)	Controller of Examinations / Registrar's nominee	CISO	DPO
LMS (SYS-05 to 09)	Dean (Academic Technology)	CISO	DPO (SYS-05 to 08)
E-mail (SYS-10 to 13)	Head, IT Services	CISO	DPO
Campus network (SYS-14 to 20)	Head, Network Operations	CISO	DPO (SYS-20 only)

5.3 Naming and boundaries so that out-of-scope requests are detected

Scope is expressed as an **allow-list**: if a target is not named, it is out of scope (default deny). Each asset is identified by three attributes that must agree – register ID (SYS-nn), IP address and host name. Wildcards (such as *.example.edu) and whole subnets are never accepted unless a CIDR is written out and signed. Findings use FND-NNN-NN names that include the

engagement number, so that a finding can be traced to its authorization. The runtime check has five tests:

Check	Test	Result on failure
S1	Address lies inside a named out-of-scope network	Reject: out-of-scope network
S2	Address is not in the asset register	Reject: unknown asset
S3	Asset is registered but not authorized for this engagement	Reject: not authorized
S4	Current date is outside the authorized dates	Reject: outside dates
S5	Current time is outside 23:00–05:00 IST	Reject: outside window

The check was implemented and run on seven test requests (engagement ENG-2026-007 with only SYS-09 authorized). Every result matched the expectation:

Test request	Expected	Actual	Reason returned
S-valid: SYS-09 inside window	In scope	In scope ✓	in scope
S-boundary: 04:59 (last minute)	In scope	In scope ✓	in scope
S-boundary: 05:00 (window closed)	Rejected	Rejected ✓	S5 outside 23:00-05:00 testing window
S-invalid: registered but not authorized	Rejected	Rejected ✓	S3 SYS-07 is registered but not authorized for this engagement
S-invalid: payroll ERP network	Rejected	Rejected ✓	S1 address is inside a named out-of-scope network
S-invalid: unregistered address	Rejected	Rejected ✓	S2 address not in asset register
S-invalid: outside dates	Rejected	Rejected ✓	S4 outside authorized dates

5.4 Transformation of the RoE into a pre-engagement checklist

Each RoE section is converted into a yes/no check that must be completed and signed by the Governance Team before the tester receives the “go” message. Twelve RoE sections produce sixteen checks.

#	Checklist item (answer Yes / No)	From RoE section	Verified by
1	Engagement ID exists in the register and status is APPROVED	1	Governance Team
2	D1 has the system-owner and CISO signatures; DPO signature if personal data	12	Governance Team
3	SHA-256 of D1/D2 equals the hash in the register	12	Governance Team
4	DPIA reference present for every personal-data target	8	DPO
5	Every target has register ID + IP + host name that agree	3	Governance Team
6	No target lies in an out-of-scope network; vendor consent attached for vendor-hosted systems	3, 4	Governance Team

#	Checklist item (answer Yes / No)	From RoE section	Verified by
7	Window is 30 days or less, in the future, and outside blackout dates	5	Governance Team
8	SOC and network team informed of IPs, window and tester IPs	5, 9	CISO office
9	Permitted tools are configured with the agreed rate limits	6	Tester lead
10	Prohibited techniques list read and acknowledged by each tester	7	Tester lead
11	Test accounts issued; no real accounts used	6, 7	System owner
12	Each tester has signed the code of conduct; external testers have an NDA	12	Governance Team
13	Escalation contacts and the HALT word confirmed by phone	9, 10	Tester lead
14	Backup or snapshot of the target exists (or rollback plan agreed)	10	System owner
15	Lab rehearsal completed and D5 lab record signed	6	Tester lead
16	Evidence store ready; redaction and retention rules explained	8, 11	Governance Team

TASK 6 – Build an Authorization and Disclosure Layer (5 Marks)

6.1 Authorization workflow

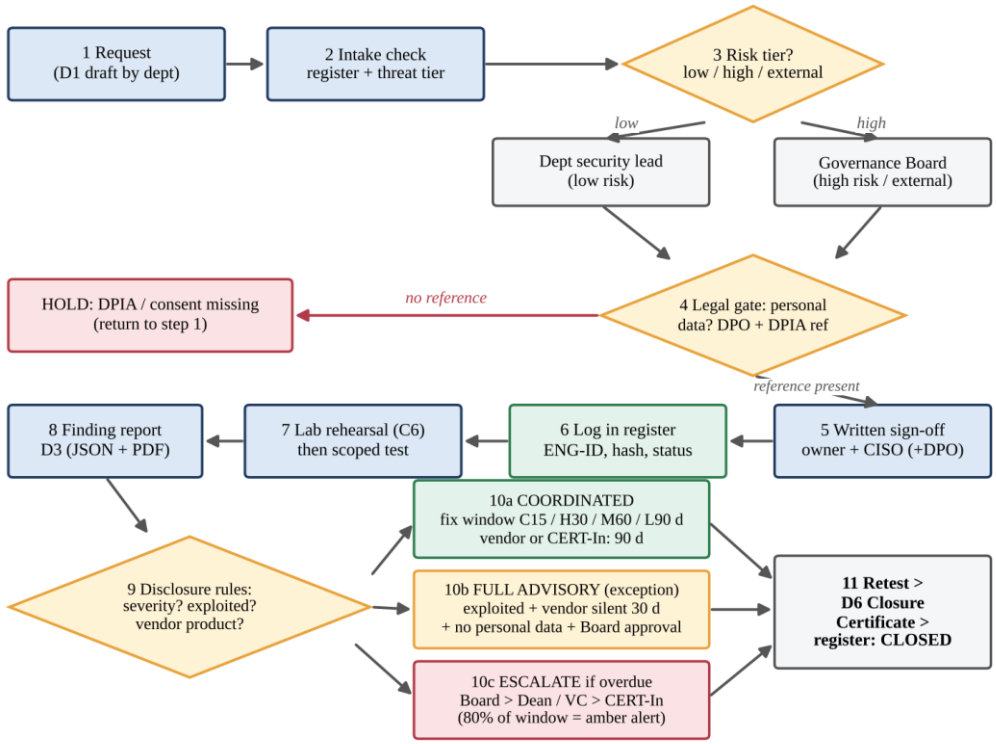


Figure 3: Authorization workflow (steps 1–6), testing (7–8) and disclosure (9–11)

Step	Actor	Input → output	Target time	Log entry
1 Request	Requesting department	D1 draft → submitted request	—	SUBMITTED
2 Intake check	Governance Team	Register, threat tier, vendor-hosting check → INTAKE_OK or return	4 working hours	INTAKE_OK
3 Risk tier	Governance Team	Low → department security lead; high or external → Board	—	TIER_SET
4 Legal gate	DPO	PD present → DPIA reference required; otherwise HOLD	1 working day	LEGAL_OK or LEGAL_HOLD
5 Sign-off	System owner, CISO (+DPO)	Dual signature → APPROVED	1 working day	APPROVED + hash
6 Record	Governance Team	Register entry, SOC notice, RoE issued	2 working hours	ACTIVE when window opens

Status model: DRAFT → SUBMITTED → INTAKE_OK → LEGAL_OK (or LEGAL_HOLD → back to SUBMITTED) → APPROVED → ACTIVE → TESTING_DONE → REPORTED → DISCLOSING → CLOSED. Terminal alternative states are REJECTED,

EXPIRED (window ended without testing) and REVOKED. Only the listed transitions are allowed; any other change is refused and logged.

6.2 Responsible (coordinated) disclosure process

Coordinated disclosure means that the finder first tells the party that can fix the problem, gives it a fair time to do so, and publishes details only afterwards or when the time has expired. The university process adopts the industry reference points that were read from Anthropic's public pages linked from claude.com: the Anthropic Responsible Disclosure Policy (reports through a HackerOne form; one vulnerability per report with summary, severity, steps to reproduce, impact and suggested fix; acknowledgement within three business days; no access to or retention of data beyond what is needed; no payment demands; safe harbour for good-faith research) and the Anthropic Coordinated Vulnerability Disclosure process (a standard 90-day deadline, a 14-day extension if the vendor is making progress, a 7-day target for actively exploited critical flaws, escalation after 30 days of silence, and withholding of full technical details for 45 days after a patch).

Reporting format (D3) – minimum content

Finding ID, engagement ID, title, affected asset (register ID), date discovered and date validated (T0), severity and CVSS score, description, steps to reproduce (without personal data), evidence (redacted), impact, recommended fix, whether the asset is third-party, whether the flaw is exploited in the wild, whether personal data is exposed, tester name and status.

Remediation windows and timeline

Event	Day (T0 = validation date)	Rule
Owner notified	T0 + 1 day (Critical: within 4 hours)	CISO informs the system owner; DPO if personal data is involved
Owner acknowledges and gives a plan	T0 + 3 working days	Same as the 3-business-day acknowledgement of the industry reference
Fix window by severity	Critical 15 / High 30 / Medium 60 / Low 90 days	Actively exploited: 7 days, whatever the severity
Vendor or CERT-In notified (third-party product)	T0 + 1 day	Vendor deadline 90 days; 14-day extension if the vendor shows progress
Amber alert	80 % of the window used	Reminder to owner and Dean
Overdue	Window exceeded	Escalate to Board, then Dean/VC; inform CERT-In for third-party products
Retest and closure	Within 5 working days of the fix	D6 Closure Certificate

Comparison with full disclosure and bug bounty

Aspect	Coordinated disclosure	Full (immediate public) disclosure	Bug-bounty programme
Idea	Tell the owner first; publish after a fixed period or after the fix	Publish details immediately to everyone	Open invitation to outside researchers with rewards under published rules
Benefit	Fix before attackers learn the details; fair to the owner	Forces quick action; warns users when a vendor is silent	Wide testing; pay only for valid finds
Risk	Owner may delay; needs deadlines and escalation	Attackers get a free exploit; personal data at risk	Needs staff to triage; scope abuse; payment and tax handling
Control of timeline	High (deadline set in advance)	None	Medium (programme rules)
Fit for the university	Default for all findings	Exception only (see 6.4)	Later stage: public safe-harbour and bounty after the programme matures

6.3 Operations for logging approvals, status updates and disclosure decisions

Three operations implement the layer. They are implemented in the model (framework.py) so that they can be run and tested.

Operation	Definition	Output
op1 log_event(eng_id, actor, action, status)	Appends a record with timestamp, actor, action, new status and the hash of the previous record (hash chain). Records are never edited; a correction is a new record.	Tamper-evident audit trail
op2 authorize(form, today)	Runs checks A1–A10 (ID format, dual signature, window length, back-dating, targets in register, tester NDA, DPIA reference, prohibited techniques, vendor consent, blackout calendar).	APPROVED / HOLD / REJECTED + reasons
op3 disclosure(finding)	Chooses the route and deadline; adds actions (DPO, 80 % amber, overdue escalation).	Route, deadline in days, actions

Sample hash-chained log for ENG-2026-007 (hash values shortened):

```
seq  time (IST)       actor       action              status       prev-hash  this-hash
001  02-Nov 10:05     Dean        submit D1           SUBMITTED    0000       a3f1
002  03-Nov 09:20     Gov. Team   intake check passed INTAKE_OK    a3f1       7c2e
003  04-Nov 11:00     DPO         DPIA-2026-003 added LEGAL_OK     7c2e       19bd
004  05-Nov 15:30     CISO+Owner  sign-off, hash stored APPROVED   19bd       e04a
005  09-Nov 23:00     Gov. Team   window opens        ACTIVE       e04a       5d8c
```

Deciding when disclosure may proceed. Disclosure of a finding to anyone outside the owner group may proceed only when **all** of the following are true: (1) the finding is validated and T0 is recorded; (2) the owner has been notified and acknowledged; (3) the fix is verified by retest **or** the fix window has expired with the Board's decision recorded; (4) the advisory contains no

personal data, credentials or exploit code; (5) legal counsel has reviewed it; (6) for full disclosure, the Board has approved in writing.

6.4 Rules for choosing coordinated or full disclosure

Rule	Condition	Route
D1	Personal data is exposed (any severity)	Coordinated only, internal; DPO informed at once; full disclosure forbidden
D2	Flaw is in a university-owned system	Coordinated (owner fixes first; an advisory is internal only)
D3	Flaw is in a third-party product, not exploited	Coordinated with the vendor or CERT-In; 90 days (+14 if progress)
D4	Flaw is exploited in the wild	Deadline 7 days; mitigation advice to users may be issued early
D5	Exploited in the wild AND vendor silent for 30 days or more AND no personal data AND Board approves	Full advisory (mitigations only; no exploit code)
D6	Anything else	Coordinated

The six rules were run on six sample findings. Results (baseline timeline):

Finding	Route chosen	Deadline (days)	Actions produced
F1 High, owner-fixable, day 10	COORDINATED (internal owner, then advisory)	30	track
F2 High, day 25 (80% rule)	COORDINATED (internal owner, then advisory)	30	amber: 80% of window used - reminder to owner
F3 Critical, day 20 (delayed)	COORDINATED (internal owner, then advisory)	15	OVERDUE by 5 d: escalate to Governance Board; owner's Dean/VC
F4 Medium in vendor product, day 5	COORDINATED (vendor/CERT-In)	90	track
F5 Exploited bug, vendor silent 35d	FULL ADVISORY (needs Board approval)	7	OVERDUE by 28 d: escalate to Governance Board; inform CERT-In
F6 Same but personal data exposed	COORDINATED (vendor/CERT-In)	7	notify DPO immediately; 72-hour data-breach clock starts if data was actually compromised; OVERDUE by 28 d: escalate to Governance Board; inform CERT-In

6.5 Interaction with the RoE and legal-compliance components

Interaction	How the layer uses the other component	Test that demonstrates it	Result
Authorization ↔ Legal	A personal-data target without a DPIA reference puts the request on HOLD	I6 (SYS-03, no DPIA)	HOLD

Interaction	How the layer uses the other component	Test that demonstrates it	Result
Authorization ↔ RoE (scope)	Targets must exist in the register; unknown target is refused	I3 (SYS-99)	REJECTED
Authorization ↔ RoE (techniques)	Prohibited technique list from the RoE is checked in the form	I5 (DoS listed)	REJECTED
Authorization ↔ RoE (calendar)	Blackout and 30-day limit from the RoE are enforced	B2, R2	REJECTED
Disclosure ↔ Legal	Personal data exposure forces coordinated route and DPO action	F6	Coordinated + DPO + 72-hour note
Disclosure ↔ Authorization	A finding can be reported only against an engagement and target that were authorized	Finding test I2 (Task 8)	REJECTED
Disclosure ↔ Ethics	Payment demand or threat makes disclosure unacceptable	Conduct case U3	UNACCEPTABLE

TASK 7 – Design an Isolated Ethical-Hacking Lab (5 Marks)

7.1 Lab design

The lab is a set of virtual machines on one host computer, connected only by a **host-only network** (192.168.56.0/24). It has one tester machine (Kali Linux) and several deliberately vulnerable or synthetic-data targets. No virtual adapter connects the lab to the campus LAN or the Internet, so a mistaken command cannot reach a production system.

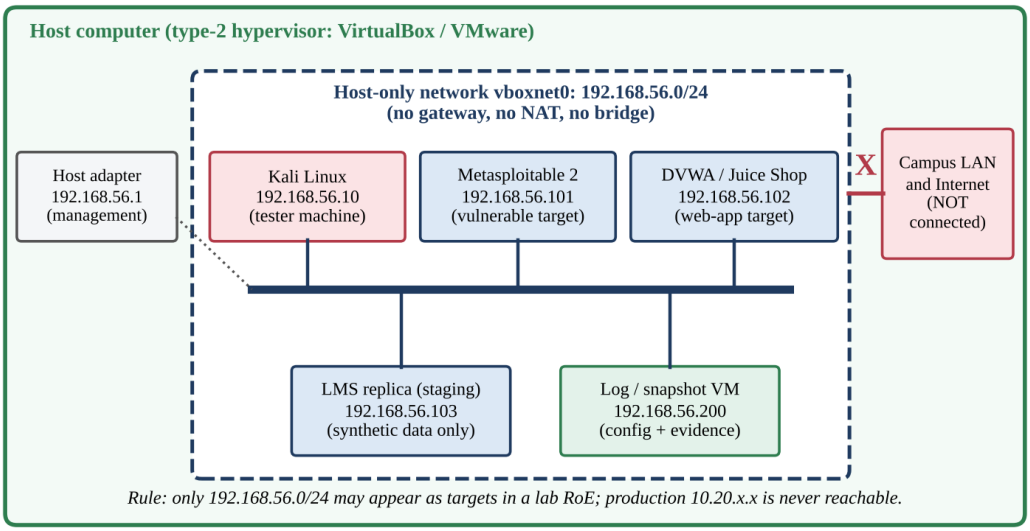


Figure 4: Isolated lab – Kali Linux and authorized targets on a host-only network

Components, roles and addressing

VM / component	Role	Address	Resources	Notes
Host computer	Runs the hypervisor (VirtualBox or VMware Workstation)	192.168.56.1 (host adapter)	16 GB RAM, 4+ cores, 100 GB disk	Management only; IP forwarding disabled; not a target
Kali Linux (current rolling release)	Tester machine – attacker role	192.168.56.10	4 GB RAM, 2 vCPU, 40 GB	Tools: nmap, Nikto, Burp Community, sqlmap, Metasploit (lab use only)
Metasploitable 2	Intentionally vulnerable Linux target for network-service practice	192.168.56.101	1 GB RAM, 1 vCPU	Never given real data
DVWA or OWASP Juice Shop	Intentionally vulnerable web-application target	192.168.56.102	2 GB RAM, 1 vCPU	Practise injection, XSS, access control
LMS replica (staging)	Rehearsal copy of the LMS (same version and plugins) for ENG-2026-007	192.168.56.103	4 GB RAM, 2 vCPU	Synthetic data only – no production data is ever copied
Log / snapshot VM	Stores D5 lab record, command logs, evidence hashes	192.168.56.200	1 GB RAM, 1 vCPU	Write-once folder for evidence

Address plan: .1 host; .10–.19 tester machines; .100–.199 targets; .200–.209 infrastructure. DHCP is switched off, so every address is static and recorded. **Connectivity rules:** Kali → targets: allowed on all ports; targets → Kali: replies and lab exercises (such as reverse connections) allowed inside the subnet; any VM → campus LAN or Internet: no route; host → VMs: management only (SSH, console). Shared folders, shared clipboard, drag-and-drop and USB pass-through are disabled.

Creating the isolated network (VirtualBox commands)

```
VBoxManage hostonlyif create                          # creates vboxnet0
VBoxManage hostonlyif ipconfig vboxnet0 --ip 192.168.56.1 --netmask 255.255.255.0
VBoxManage dhcpserver remove --ifname vboxnet0              # static addressing only
VBoxManage modifyvm "Kali" --nic1 hostonly --hostonlyadapter1 vboxnet0 --nic2 none
VBoxManage modifyvm "Metasploitable2" --nic1 hostonly --hostonlyadapter1 vboxnet0 --nic2 none
VBoxManage snapshot "Kali" take clean-baseline              # repeat for every VM
```

Command names and options can differ slightly between VirtualBox versions; the commands above document the intended configuration and are recorded in D5. The lab was not executed in this assignment (no live testing is performed); the verification operations below give the expected results and the address-guard logic was executed in the model.

7.2 Recording the lab configuration

Step	Action	Record (stored in D5)
1	Export the hypervisor view: VBoxManage list vms; VBoxManage showvminfo <vm> --machinereadable; VBoxManage list hostonlyifs	Adapter type, MAC, network name per VM
2	Inside each VM: ip -br addr; ip route; uname -r; dpkg -l | sha256sum (or rpm -qa)	Address, routes, kernel and package-list hash
3	Take a snapshot called clean-baseline; export OVA files and compute sha256sum of each	Snapshot name, OVA hash
4	Compare LMS replica version and plugin list with production (read-only inventory)	Fidelity statement: identical / differences listed
5	Tester lead and Governance Team sign D5; D5 hash is added to the engagement log	Signatures, date, hash

7.3 Operations on the lab

Operation 1 – Verify connectivity and isolation

Check (run on Kali)	Command	Expected result	Proves
Own address	ip -br addr	eth0 UP 192.168.56.10/24	Correct address
Routing table	ip route	Only 192.168.56.0/24 and no default gateway	No path out
Reach target 1	ping -c 3 192.168.56.101	3 replies, 0 % loss	Kali ↔ target works

Check (run on Kali)	Command	Expected result	Proves
Reach target 2 and 3	ping -c 3 192.168.56.102 ; ping -c 3 192.168.56.103	Replies from both	All targets up
Host discovery	nmap -sn 192.168.56.0/24	Hosts .1 .10 .101 .102 .103 .200 only	No unknown host
Internet test (negative)	ping -c 2 8.8.8.8	"Network is unreachable" / 100 % loss	No Internet route
Production test (negative)	ping -c 2 10.20.1.10	"Network is unreachable" / 100 % loss	No route to campus systems

Operation 2 – Record the lab set-up (lab_record)

```
for vm in Kali Metasploitable2 DVWA LMS-replica Logger; do
  VBoxManage showvminfo "$vm" --machinereadable | grep -E 'nic|hostonly|VMState' >> d5_record.txt
done
ip -br addr >> d5_record.txt ; ip route >> d5_record.txt ; date -Is >> d5_record.txt
sha256sum d5_record.txt | tee -a engagement_log.txt     # hash goes into the hash-chained log
```

Operation 3 – Lab address guard (target check before any command)

Every lab command is run through a guard that accepts only IP addresses inside 192.168.56.0/24, excluding the host adapter. Host names and wildcards are refused. The guard was implemented and run on seven inputs:

Target given	Expected	Actual	Reason
192.168.56.101	Accept	Accept ✓	inside lab CIDR
192.168.56.254	Accept	Accept ✓	inside lab CIDR
192.168.56.1	Refuse	Refuse ✓	host adapter is not a target
192.168.57.5	Refuse	Refuse ✓	outside lab CIDR
10.20.1.10	Refuse	Refuse ✓	outside lab CIDR
8.8.8.8	Refuse	Refuse ✓	outside lab CIDR
*.example.edu	Refuse	Refuse ✓	not an IP literal (hostnames/wildcards refused)

Operation 4 – Restore to baseline

After each exercise the target VMs are restored with VBoxManage snapshot <vm> restore clean-baseline, so that every rehearsal starts from the recorded state and no malware or changed configuration is carried to the next engagement.

7.4 Host-only versus NAT (and other options)

Criterion	Host-only (chosen)	NAT	Bridged	Internal network
Access to the Internet	None	Outbound yes	Yes (through the campus LAN)	None

Criterion	Host-only (chosen)	NAT	Bridged	Internal network
Access to campus systems	None	Outbound possible (through host NAT)	Yes – dangerous	None
Host can manage VMs	Yes	Yes (port forwarding needed)	Yes	No (only inside the VMs)
VMs can reach each other	Yes	No by default (each VM alone behind NAT)	Yes	Yes
Risk of scanning a real system by typing error	Very low	High (Internet addresses reachable)	Very high	Very low
Software updates	Not possible while connected (done offline in update mode)	Possible	Possible	Not possible
Suitability for Kali + targets lab	Best	Not suitable for testing; allowed only for update mode	Not allowed	Possible but hard to manage

Justification. The legal risk in a lab is a scan or exploit that leaves the lab: under IT Act s.43/s.66 and CFAA §1030(a)(2) that would be unauthorized access to someone else's system. Host-only networking gives the strongest guarantee that is still convenient, because it still allows the host to manage the VMs and lets all VMs talk to each other. NAT gives outbound Internet access, so a mistyped address or a wrongly configured tool could reach real hosts. The compromise is an **update mode**: when Kali needs updates, the targets are powered off, a NAT adapter is attached to Kali only for the update, and it is removed again before the verification checks of Operation 1 are repeated and D5 is re-signed.

7.5 How the lab keeps testing authorized and contained

- **Authorized:** a lab engagement has its own authorization (a short D1) that lists the lab addresses as the only targets; lab access is given only to testers named in D1 who have signed the code of conduct.
- **Contained by network:** no gateway, no NAT, no bridge, DHCP off; negative tests in Operation 1 prove that 8.8.8.8 and 10.20.1.10 cannot be reached.
- **Contained by software guard:** the address guard refuses any target outside 192.168.56.0/24 (7 of 7 test inputs correct).
- **Safe content:** only intentionally vulnerable machines and synthetic data are used; the LMS replica never contains production records, so a lab mistake cannot expose personal data.
- **Recoverable and auditable:** snapshots restore a clean state; D5 and command logs are hashed into the engagement log.

TASK 8 – Develop a Reusable Document Library (5 Marks)

The library has six reusable documents. All share three keys – engagement ID, asset IDs and the date format (YYYY-MM-DD) – so that a document produced by one component can be consumed by another.

Doc	Name	Used by	Output
D1	Authorization Form	C1	Signed PDF + register entry (status APPROVED)
D2	Scope and Rules-of-Engagement Sheet	C2	Allow-list, window, technique lists (Task 5)
D3	Finding Report	C6, C7	Structured JSON + PDF; feeds disclosure decisions
D4	Disclosure Advisory / Notice	C7	Owner notice and, if allowed, advisory text
D5	Lab Configuration Record	C6	Signed lab record with hashes
D6	Closure and Retest Certificate	C1, C7	Register status CLOSED

8.1 D1 – Authorization Form (fields and defaults)

Field	Type / format	Default	Validation rule (check)
Engagement ID	ENG-YYYY-NNN	Next free number	Must match pattern (A1)
Title and objective	Text (max 200 characters)	—	Not empty
Requester and system owner	Name, role	—	Role on authority matrix
Signatures	System owner, CISO (+DPO)	—	Owner AND CISO present (A2)
Start and end date	YYYY-MM-DD	Start = approval date + 5 days; end = start + 13 days	End not before start; at most 30 days unless extension; not in the past (A3, A4)
Testing hours	Time range	23:00–05:00 IST	Must lie inside the standard window
Targets	List of SYS-nn	—	All in register; none out-of-scope (A5)
Hosting	Own / vendor	Own	If vendor: consent reference required (A9)
Testers	Name, internal/external, NDA	Internal	At least one; external → NDA = yes (A6)
Techniques	From list in D2	port_scan, vuln_scan	No prohibited technique (A8)
Personal data involved	Yes/No (auto-filled from register)	Auto	If yes: DPIA reference required (A7)
Lab rehearsal required	Yes/No	Yes for any PD target	—
Extension approved	Board reference	None	Required if window above 30 days
Document hash	SHA-256	Computed on signing	Stored in register (AV4)

8.2 D3 – Finding Report (fields) and structured output

Field	Content / default	Rule
id	FND-<eng>-<nn>	Unique, generated
engagement	ENG-YYYY-NNN	Must be an APPROVED engagement
title	Short description	1–120 characters
target	Register ID	Must be one of the authorized targets
severity, cvss	Critical 9.0–10.0, High 7.0–8.9, Medium 4.0–6.9, Low 0.1–3.9	CVSS must lie in the band of the severity
description, steps, impact	Free text	No personal data
evidence	Redacted output or screenshot description	No e-mail address or 12-digit number pattern (PD check)
remediation	Recommended fix	Required
third_party_product, exploited, personal_data_exposed	false (default)	Boolean flags that drive the disclosure route
validated_on (T0)	Date	Starts the disclosure clock

Structured output. On acceptance, D3 is written as a JSON object. The disclosure component (C7) reads this object directly; no re-typing is needed. The example below is the finding of the walkthrough (Task 9):

```
{ "id": "FND-007-01", "engagement": "ENG-2026-007", "target": "SYS-09",
 "title": "SQL injection in quiz-export endpoint of vendor plugin",
 "severity": "High", "cvss": 8.1, "validated_on": "2026-11-14",
 "third_party_product": true, "exploited": false, "personal_data_exposed": true,
 "remediation": "Disable endpoint; apply vendor patch; use parameterised queries" }
   ↓ disclosure(finding) ↓
 route: COORDINATED (vendor/CERT-In) | deadline: 90 d vendor, 30 d for university deployment
 actions: notify DPO immediately; track amber at 80 % of window
```

8.3 D4, D5, D6 – content

Doc	Fields	Defaults and rules
D4 Disclosure Advisory / Notice	Advisory ID, finding ID, affected product and versions, summary (no exploit code), severity, workaround, fix status, timeline (T0, notice, fix, publication), contacts, credit line (with permission)	Audience default = owner group; public publication needs Board approval (rule D5) and legal review; personal data is never included
D5 Lab Configuration Record	Lab ID, host details, VM list with role and IP, adapter mode, snapshot names, OVA hashes, fidelity statement, signatures, date	Adapter mode default = host-only; any other mode makes the record INVALID
D6 Closure and Retest Certificate	Finding ID, fix date, retest date and result (Pass/Fail), residual risk, evidence hash, signatures of owner and Governance Team	Register status becomes CLOSED only on Pass; on Fail the finding returns to DISCLOSING

8.4 Test entries: valid, boundary and invalid inputs

The document rules were encoded and executed. The first table tests D1 (authorization checks, today's date in the model = 2 Nov 2026); the second tests D3.

D1 Authorization Form – 17 entries

Entry	Expected	Actual	Reason(s) returned
V1 valid: 14-day window, non-PD system	APPROVED	APPROVED ✓	all checks A1-A8 passed
V2 valid: PD system with DPIA reference	APPROVED	APPROVED ✓	all checks A1-A8 passed
B1 boundary: window exactly 30 days	APPROVED	APPROVED ✓	all checks A1-A8 passed
B2 boundary: window 31 days, no extension	REJECTED	REJECTED ✓	A3 window longer than 30 days without Board extension
B3 boundary: starts today (same-day)	APPROVED	APPROVED ✓	all checks A1-A8 passed
B4 boundary: 31 days WITH Board extension	APPROVED	APPROVED ✓	all checks A1-A8 passed
I1 invalid: CISO signature missing	REJECTED	REJECTED ✓	A2 dual sign-off (system owner + CISO) missing
I2 invalid: back-dated start (1 Nov)	REJECTED	REJECTED ✓	A4 back-dated authorization (start before approval date)
I3 invalid: target not in register	REJECTED	REJECTED ✓	A5 target SYS-99 not in asset register (out of scope)
I4 invalid: external tester without NDA	REJECTED	REJECTED ✓	A6 external tester X Ltd has no signed NDA
I5 invalid: DoS listed as technique	REJECTED	REJECTED ✓	A8 prohibited technique(s): dos
I6 hold: PD system, no DPIA reference	HOLD	HOLD ✓	A7 targets hold personal data but no data-protection impact reference (DPO sign-off)
I7 invalid: malformed ID 'ENG-26-7'	REJECTED	REJECTED ✓	A1 invalid engagement ID format
I8 invalid: empty form (no authorization at all)	REJECTED	REJECTED ✓	A1 invalid engagement ID format; A2 dual sign-off (system owner + CISO) missing; A3 testing window missing; A5 no targets listed; A6 no named tester
R1 refinement P1: vendor-hosted SYS-09, no consent	HOLD	HOLD ✓	A9 target is vendor-hosted but no written third-party consent attached
R2 refinement P2: window 10-20 Dec overlaps blackout	REJECTED	REJECTED ✓	A10 testing window overlaps examination blackout calendar
R3 refinement P2: window ends 13 Dec (boundary, ok)	APPROVED	APPROVED ✓	all checks A1-A8 passed

D3 Finding Report – 10 entries

Entry	Expected	Actual	Reason(s) returned
V1 valid High 8.1	ACCEPTED	ACCEPTED ✓	all checks passed

Entry	Expected	Actual	Reason(s) returned
B1 CVSS 7.0 labelled High (lower bound)	ACCEPTED	ACCEPTED ✓	all checks passed
B2 CVSS 8.9 labelled High (upper bound)	ACCEPTED	ACCEPTED ✓	all checks passed
B3 CVSS 9.0 labelled High (band mismatch)	REJECTED	REJECTED ✓	F2 CVSS does not match severity band
B4 title exactly 120 characters	ACCEPTED	ACCEPTED ✓	all checks passed
B5 title 121 characters	REJECTED	REJECTED ✓	F3 title longer than 120 characters
I1 CVSS 10.1	REJECTED	REJECTED ✓	F2 CVSS outside 0.0-10.0
I2 target SYS-12 not in engagement	REJECTED	REJECTED ✓	F4 target not authorized for this engagement
I3 evidence contains e-mail address	REJECTED	REJECTED ✓	F5 evidence contains personal data - redact and resubmit
I4 missing remediation	REJECTED	REJECTED ✓	F1 missing field remediation

Result: 17 of 17 D1 entries and 10 of 10 D3 entries gave the expected result. Boundary entries (30 days v 31 days; CVSS 8.9 v 9.0; 120 v 121 characters; 04:59 v 05:00) show exactly where each rule changes.

8.5 Evidence of integration with the framework

Document	Produced by	Consumed by	Integration evidence
D1 → register	C1	C2, C6, C7	Engagement ID, targets and window are read by the scope check (S3, S4) and by D3 validation (F4)
D2 → checklist	C2	Governance Team	16 checklist items derived from the 12 RoE sections
D3 JSON → disclosure()	C6	C7	Flags third_party_product, exploited, personal_data_exposed decide route and deadline (F1–F6)
D3 → legal	C7	C3	personal_data_exposed starts the DPO and 72-hour process
D5 → D1	C6	C1	A PD engagement requires a signed D5 (checklist item 15)
D6 → register	C7	C1	Status CLOSED only after Pass

TASK 9 – Integrate, Test and Refine the Framework (5 Marks)

9.1 Integration of Tasks 2–8

The components are connected through one engagement record and a fixed lifecycle. Table below shows the lifecycle phases, which components act in each phase, which document is produced and which gate must be passed.

Phase	Components used	Document	Gate (pass condition)
0 Prepare	C4 threat model, C3 legal map, C5 code	Reference documents	Annual review by the Board
1 Request and intake	C1, C2, C4	D1 draft	Targets in register; tier set
2 Legal gate	C3, DPO	DPIA reference	Reference present for PD targets
3 Authorization	C1, C8	D1 signed, D2, register entry	Dual signature; hash stored; checks A1–A10 pass
4 Lab rehearsal	C6, C5	D5	Isolation checks pass; D5 signed
5 Scoped testing	C2, C5, C6	Logs, D3 draft	Runtime scope check S1–S5; stop-and-ask rule
6 Reporting and triage	C7, C3	D3 JSON	Validation F1–F5 pass; route and deadline set
7 Disclosure and closure	C7, C1	D4, D6	Fix verified by retest; status CLOSED

9.2 Walkthrough of an authorized assessment (ENG-2026-007)

Situation. Before the LMS upgrade, the Dean of the School of Computing asks for an assessment of the LMS web tier and its vendor-hosted plugin server (SYS-05, SYS-06, SYS-09). The dates are illustrative.

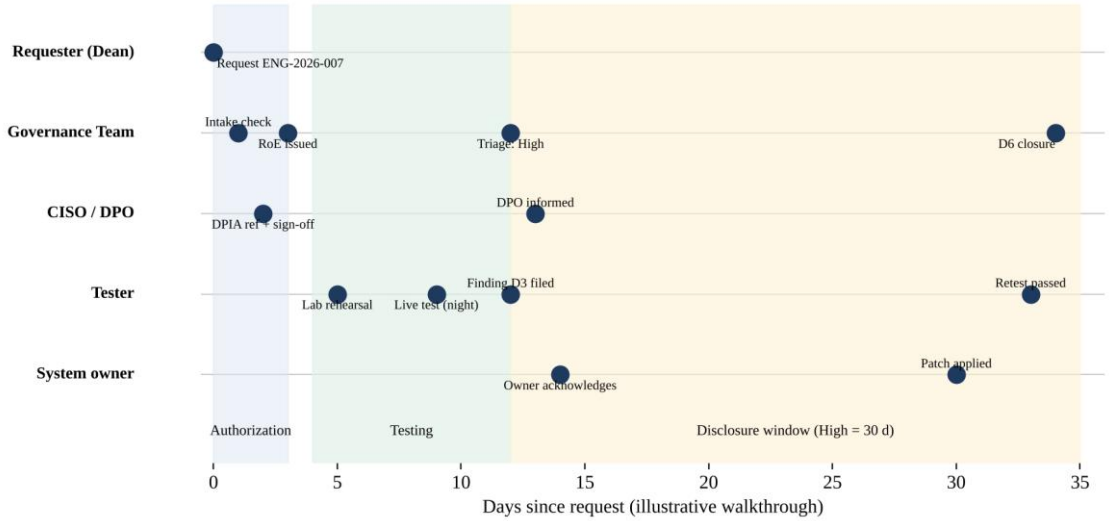


Figure 5: Timeline of the walkthrough (authorization, testing, disclosure)

Day (date)	Step	What happens	Component / document
0 (2 Nov)	Request	Dean submits the D1 draft with targets SYS-05, SYS-06, SYS-09, window 10–20 Dec, two internal testers	C1, D1
1 (3 Nov)	Intake	Register check passes. The team notices that SYS-09 runs on the vendor's hosting (problem P1). Request returned for vendor consent	C1, C2
2 (4 Nov)	Legal gate	LMS holds personal data; DPO supplies DPIA-2026-003; vendor consent VENDOR-CONSENT-117 attached	C3
3 (5 Nov)	Sign-off and record	Owner and CISO sign; PDF hash stored; RoE issued; SOC informed. Checklist items 1–14 are ticked. Calendar check shows that the requested window of 10–20 Dec overlaps the end-semester examination blackout starting 14 Dec (problem P2); the window is moved to 9–22 Nov	C1, C2, D2
5 (7 Nov)	Lab rehearsal	Testers rehearse on the LMS replica 192.168.56.103 (synthetic data). The plugin version differs by one minor release between lab and production (problem P5); the lab record states the difference	C6, D5
9 (11 Nov, 23:30)	Scoped live test	Rate-limited scan of SYS-09 inside the window. A suspected SQL injection in the quiz-export endpoint is confirmed with one harmless request. The error page shows one student's name and roll number (problem P3). The tester stops, does not copy it, records the incident and informs the DPO (case B2: BORDERLINE)	C2, C5
12 (14 Nov)	Finding report	D3 accepted: severity High, CVSS 8.1. The first draft contained the name in a screenshot and was rejected by rule F5; redacted version accepted. T0 is set to the validation date (problem P4: when does the clock start?)	D3, C7
12–13	Triage	disclosure(): third-party product, not exploited, personal data exposed → COORDINATED; DPO informed; DPO records that an authorized tester saw the item incidentally and no data left the university's control, so no breach notice is required (design assumption to be confirmed by the DPO); no listed incident, so no CERT-In report	C7, C3
13	Notification	Owner and vendor notified; vendor deadline 90 days; university deployment must be fixed within the High window of 30 days (until day 42)	C7, D4
14–30	Remediation	Owner acknowledges on day 14, disables the endpoint on day 15 (mitigation), applies the vendor patch on day 30 (amber alert not reached)	C7
33–34	Retest and closure	Retest passes on day 33; D6 issued on day 34; register status CLOSED; log chain verified	D6, C1

9.3 Systematic test cases

Twelve test cases cover the four risk categories. They were executed against the model of the final (refined) framework; expected results were written before the run.

ID	Category	Test	Expected	Actual
M1	Missing authorization	CISO signature missing	REJECTED	REJECTED ✓
M2	Missing authorization	Empty form submitted	REJECTED	REJECTED ✓

ID	Category	Test	Expected	Actual
M3	Missing authorization	Start date earlier than approval date (back-dating)	REJECTED	REJECTED ✓
O1	Out-of-scope request	Target SYS-99 not in register	REJECTED	REJECTED ✓
O2	Out-of-scope request	Runtime request to payroll ERP 10.30.1.25	Rejected	Rejected ✓
O3	Out-of-scope request	Registered system SYS-07 not authorized for this engagement	Rejected	Rejected ✓
L1	Legal conflict	PD system SYS-03, no DPIA reference	HOLD	HOLD ✓
L2	Legal conflict	External tester without NDA	REJECTED	REJECTED ✓
L3	Legal conflict	Denial-of-service listed (s.43(e)/(f), CFAA (a)(5))	REJECTED	REJECTED ✓
D1	Delayed disclosure	High finding, day 25 of 30 (baseline)	Amber alert	Amber alert ✓
D2	Delayed disclosure	Critical finding, day 20 of 15	Overdue → escalate	Overdue → escalate ✓
D3	Delayed disclosure	Exploited bug, vendor silent 35 days, no personal data	Full advisory (Board)	Full advisory (Board) ✓

All twelve cases gave the expected result. Together with the earlier suites, the final framework passed **58 of 58** executed checks (D1 forms, scope requests, conduct cases, lab guard, D3 reports, standing-authorization states).

9.4 Problems found in the walkthrough and refinements

#	Problem encountered	Refinement made	Component changed	Evidence after refinement
P1	SYS-09 turned out to be vendor-hosted; the draft D1 had no way to show consent from the vendor	New D1 field “Hosting” and rule A9: vendor-hosted target needs written consent, otherwise HOLD	C1, D1, C3 (L9)	Test R1 → HOLD
P2	Requested window overlapped an examination week	Blackout calendar added to D2; rule A10 rejects overlapping windows; checklist item 7	C2, C1	Tests R2 → REJECTED, R3 (boundary) → APPROVED
P3	A screenshot in the first D3 draft showed a student’s name	Evidence rule F5 (pattern check) and redaction step; conduct case B2 added	D3, C5	Finding test I3 → REJECTED
P4	Unclear when the disclosure clock starts (discovery, report or fix)	Clock fixed at T0 = validation date, recorded in D3 and in the log	C7	days_since_validation used in tests F1–F6
P5	Lab replica differed from production by one plugin version	D5 “fidelity statement” field; checklist item 15 requires it	C6, D5	D5 content (Task 8.3)
P6	Every request waited for the same Board secretariat; suspected bottleneck at scale	Tiered approval by risk (department lead for low risk) and register-linked scope check	C1, C2	Task 10 results

Final corrected framework (v1.1). v1.1 differs from the first draft by: two new authorization checks (A9 vendor consent, A10 blackout), one new finding rule (F5 personal-data pattern), a fixed disclosure clock, the D5 fidelity statement, one new conduct case, and tiered approval. All suites were re-run after the changes and passed.

TASK 10 – Create a Scalability and Governance Evaluation (5 Marks)

10.1 Evaluation setup

A small seeded simulation (sim.py, listed in Appendix B) compares two programme sizes under two governance designs. **Baseline governance** is the first version of the framework: every request, every scope check and every disclosure decision goes through one Governance Board secretariat. **Refined governance** is v1.1 after the walkthrough (P6): tiered approval, register-linked scope checking and severity-routed disclosure triage. The model is an estimate based on stated assumptions, not field data from a real university, and the results are read in that light.

Parameter	Small programme (one department)	Large programme (whole university + external assessors)
Systems in programme	5	400
Testers	3 internal	40 (including external assessors)
Engagements per month	3	30
Share of requests from external assessors	0 %	40 %
Share of high-risk requests	30 %	30 %
Systems per engagement	2	4
Findings per month	6	120 (5 % Critical, 15 % High, 40 % Medium, 40 % Low)
Department security leads (refined design)	1	8
Service times (working hours)	Approval 2.0 mean (+4.0 vetting for external in baseline); lead approval 0.75; Board triage 0.75; rule-based triage 0.25	Same
Fixed latency	4 working hours for signatures per request; 2 working hours for finding validation and owner notice	Same
Method	FCFS queue in working hours (8 h × 22 days a month); Poisson arrivals; 200 runs, seeds 2026–2225; 12 simulated months	Same

10.2 Processes tested and measures recorded

Process	Measure	How it is obtained
A Engagement approval	Mean and 90th-percentile turnaround (working days); share approved within 5 working days; number of steps	Queue simulation; steps counted from the workflow (baseline 7, external 10; refined low-risk 5, high 8, external 9)
B Scope verification	Checks per engagement	Baseline: 6 manual checks per target + 4 engagement-level; refined: 6 register-linked checks once + 1 exception check per target + 4

Process	Measure	How it is obtained
C Disclosure triage	Mean days from validated finding to routed decision	Queue simulation; baseline all findings to the Board; refined: Critical/High to Board, Medium/Low to two disclosure officers by rule
Coverage	Share of systems with an approved engagement in a quarter	Limited by approvals on time and tester capacity (1.5 engagements per tester per quarter)

10.3 Results

Measure	Small – baseline	Small – refined	Large – baseline	Large – refined
A1 Approval turnaround, mean (working days)	0.76	0.64	1.69	0.88
A2 Approval turnaround, 90th percentile (working days)	1.08	0.83	3.33	1.5
A3 Approved within 5 working days (%)	100	100	97.5	100
A4 Procedural steps per engagement (mean)	7	5.9	8.2	7.1
B1 Scope-verification checks per engagement	16	12	28	14
C1 Disclosure triage, mean (working days)	0.35	0.29	0.44	0.3
C2 Disclosure triage, Critical findings (working days)	0.35	0.34	0.44	0.35
D1 Quarterly scope coverage (% of systems)	100	100	60	60

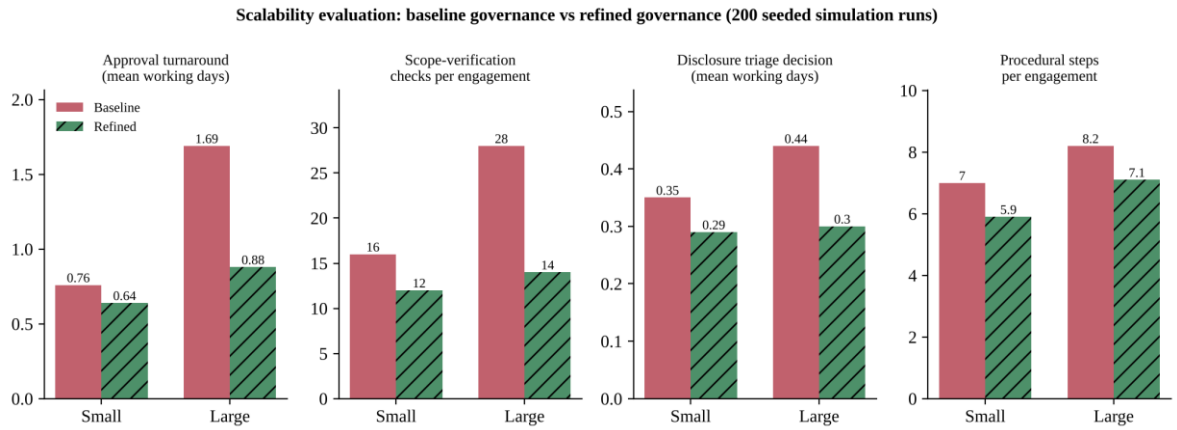


Figure 6: Baseline against refined governance for three processes at small and large scale

10.4 Interpretation

- **Baseline does not scale well.** Moving from one department to the whole university raises mean approval time from 0.76 to 1.69 working days (+122%) and the 90th percentile to 3.33 days, because all requests (and the external-assessor vetting) share one queue. Scope

checks per engagement rise from 16 to 28. DC6 (no more than 1 working day) is **not met** by the baseline at large scale.

- **Refined governance meets DC6.** At large scale the mean approval time falls to 0.88 days (48% lower), the 90th percentile to 1.5 days (55% lower), approvals within 5 working days reach 100%, scope checks fall by 50%, and disclosure triage falls from 0.44 to 0.3 days. Critical findings stay with the Board, so their speed (0.35 days) is deliberately not "optimised away".
- **At small scale the gain is small** (0.76 to 0.64 days). The tiered design is therefore justified by growth, not by the current 20 systems; it costs nothing extra to run it from the start because with one lead it behaves like the baseline.
- **Coverage is limited by tester capacity, not by governance.** Quarterly coverage is 60% for both designs at large scale: faster approvals cannot test more systems if there are not enough testers. This finding changes the governance decision: it points to risk-based prioritisation and standing authorizations (Task 11) rather than to further tuning of approvals.

10.5 Governance refinements adopted because of the evidence

#	Evidence	Refinement to governance	Trigger / KPI
G1	Single approval queue gives 3.33-day 90th percentile at large scale	Tiered approval: department security lead for low-risk internal requests; Board only for high-risk and external requests	Review tier threshold if 90th-percentile approval time exceeds 2 working days
G2	Scope checks double from 16 to 28 per engagement when systems per engagement rise	Register-linked scope check: one check against the asset register plus exceptions	Checks per engagement not above 14 at large scale
G3	All findings sent to the Board even though 80 % are Medium or Low	Severity-routed triage: Critical and High to Board, others to disclosure officers by rule	Board workload share of findings not above 20 %
G4	Coverage is capped at 60 % by tester capacity	Risk-based coverage target: all personal-data systems each year, others by risk; use external assessors when coverage falls below target	Coverage per quarter reported to the Board
G5	Approval waiting time depends on one secretariat	Utilisation alarm: add an approver when the queue utilisation exceeds 70 %	Monthly queue report

TASK 11 – Defend the Framework Under a Changed Requirement (5 Marks)

11.1 Impact of the changed requirement

Changed requirement	Why v1.1 is not enough	Components affected
Continuous assessments	v1.1 authorizes one engagement of at most 30 days. Weekly or daily automated scans would need a new approval each time (about 5,200 approvals per quarter for 400 systems scanned weekly)	C1, C2, C6
Third-party assessors	Vetting and contract terms were handled case by case in A6 (NDA only); no safe-harbour, data-processor or insurance clauses	C1, C3, C5, C8
Stricter data-protection rules	Personal-data handling was a check (A7, F5), not a gate with minimisation, redaction and a 72-hour clock; DPDP duties begin around May 2027	C3, C7
Shorter disclosure timeline	Windows of 15/30/60/90 days and 90-day vendor deadline are too long for the new policy	C7
Easy to govern and extend	New components must plug into the same engagement record and register	All

11.2 Retain, modify, replace or redesign

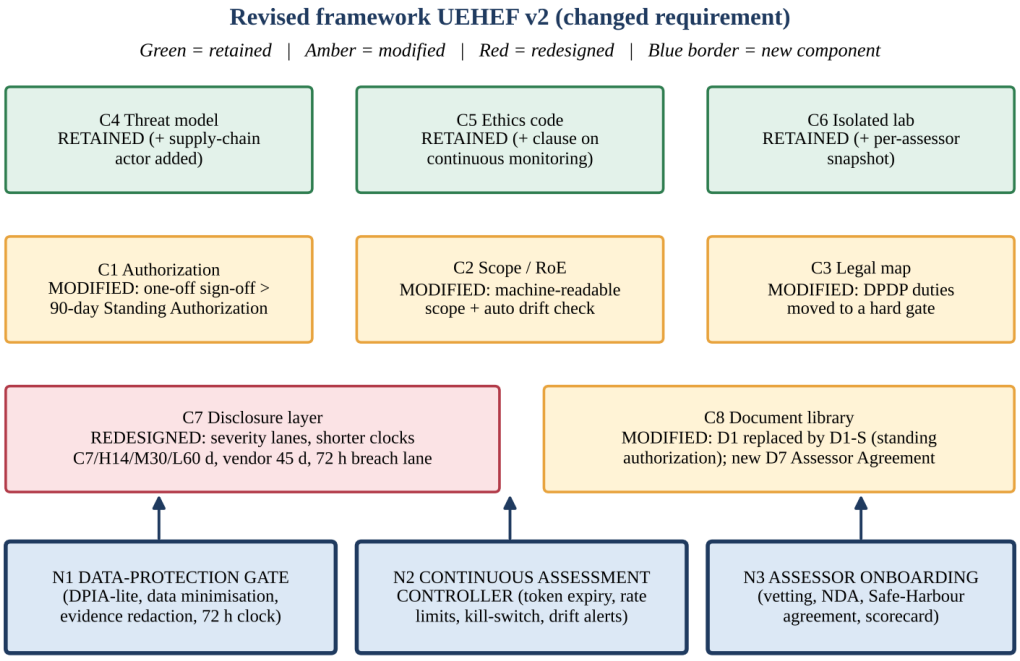


Figure 7: Revised framework UEHEF v2 – decisions on each component and the three new components

Component	Decision	What changes and why
C4 Threat model	Retain (+ one actor)	Add “supply-chain / third-party assessor” as an actor type; the classification rules stay

Component	Decision	What changes and why
C5 Ethics and code of conduct	Retain (+ one clause)	Add continuous-monitoring rules (no widening of a standing scope without approval); the decision rule is unchanged
C6 Isolated lab	Retain (+ snapshot per assessor)	Each external assessor rehearses in their own lab snapshot; design and isolation proof unchanged
C1 Authorization	Modify	Add Standing Authorization (D1-S): valid for 90 days, repeated scans in a defined scope; one-off D1 stays for intrusive tests
C2 Scope / RoE	Modify	Scope becomes machine-readable (list of IDs + register hash) so that drift can be detected automatically
C3 Legal map	Modify	Data-protection duties become a hard gate (N1) instead of a single field; add CERT-In and DPDP rows for external assessors
C8 Document library	Modify	D1 gets a standing variant; new D7 Third-Party Assessor Agreement; D3 gets a "data-protection" section
C7 Disclosure layer	Redesign	Shorter, severity-based clocks, a fast lane for exploited flaws and a 72-hour breach lane; the first design allowed too much time and had no formal link to breach duties
No component	None replaced entirely	The engagement record, the register and the document keys are kept, so everything built so far is reused

11.3 New and modified components and their integration

N1 – Data-Protection Gate (new, called by C1 and C7)

- **Before testing:** a short data-protection impact check (DPIA-lite) for every PD target; data-minimisation plan (test accounts, masked data, read-only access); processor clause signed by assessors.
- **During testing:** evidence redaction rule (pattern check F5 becomes mandatory); no copying of personal data; any sight of personal data is logged as an incidental exposure.
- **After testing:** the DPO classifies the event; where personal data was actually compromised, the 72-hour clock for the detailed report to the Data Protection Board starts at once, and where it is a listed incident the 6-hour CERT-In clock applies.

N2 – Continuous Assessment Controller with Standing Authorization (new, modifies C1/C2)

A standing authorization token carries: engagement ID, list of asset IDs, the register hash at signing time, permitted tools and rate limit (for example 2 scans per day), expiry (90 days), signers, and a kill-switch flag. Four rules apply: the token **expires** after 90 days; it is **suspended** if the asset register changes (a new system or owner appears – drift review); scans above the rate limit are **throttled**; and the CISO can **revoke** it at once. It was implemented and run on five states:

State tested	Expected	Actual
Day 1 (9 Nov 2026), same register	ACTIVE	ACTIVE ✓
Day 90 (7 Feb 2027) boundary	ACTIVE	ACTIVE ✓
Day 91 (8 Feb 2027)	EXPIRED	EXPIRED ✓
New system added to register (hash changed)	SUSPENDED (asset register changed - drift review)	SUSPENDED (asset register changed - drift review) ✓
3rd scan in one day (limit 2)	THROTTLED (rate limit exceeded)	THROTTLED (rate limit exceeded) ✓

Effect on workload: with weekly scans of 400 systems, per-scan approvals would be 400 × 13 = 5,200 per quarter. With one standing token per 10 systems the number is 40 per quarter, which is **99.2 % fewer** approvals. Intrusive testing (exploitation proofs, new tools) still requires a normal D1.

N3 – Third-Party Assessor Onboarding (new, modifies C8)

Steps: due-diligence check (identity, references, insurance); signed D7 agreement; NDA; code-of-conduct acknowledgement; data-processor clause (DPDP s.8(2)); rule that third-party and US-hosted systems stay out of scope without written consent (CFAA L9); a university **safe-harbour statement** for good-faith work inside the signed scope (modelled on the commitments in Anthropic's Responsible Disclosure Policy); rule that no payment may be demanded and no data retained; and a scorecard (on-time reports, scope violations, quality) that decides renewal.

C7 – Redesigned disclosure timeline

The same disclosure function was run with the revised windows (Critical 7, High 14, Medium 30, Low 60 days; vendor 45 days; actively exploited 7 days). The table shows how the six test findings behave under the old and new clocks.

Finding	Baseline deadline (days) and action	Revised deadline (days) and action
F1 High, owner-fixable, day 10	30 – track	14 – track
F2 High, day 25 (80% rule)	30 – amber: 80% of window used - reminder to owner	14 – OVERDUE by 11 d: escalate to Governance Board; owner's Dean/VC
F3 Critical, day 20 (delayed)	15 – OVERDUE by 5 d: escalate to Governance Board; owner's Dean/VC	7 – OVERDUE by 13 d: escalate to Governance Board; owner's Dean/VC
F4 Medium in vendor product, day 5	90 – track	45 – track
F5 Exploited bug, vendor silent 35d	7 – OVERDUE by 28 d: escalate to Governance Board; inform CERT-In	7 – OVERDUE by 28 d: escalate to Governance Board; inform CERT-In
F6 Same but personal data exposed	7 – notify DPO immediately; 72-hour data-breach clock starts if data was actually compromised	7 – notify DPO immediately; 72-hour data-breach clock starts if data was actually compromised

Finding F2 (High, day 25) was only an amber warning under the baseline but is **overdue by 11 days** under the revised 14-day window, which shows that the shorter timeline is enforced by the same code with a changed configuration. F4 (Medium finding in a vendor product) moves from a 90-day to a 45-day vendor deadline.

How the new parts connect

New / modified part	Connects to	Mechanism
N1 Data-Protection Gate	C1, C3, C7, D3	A7 becomes mandatory for standing tokens; F5 redaction; DPO flag drives the 72-hour lane
N2 Controller	C1, C2, register	Token stored in register; register hash compared on each scan; log entries per scan batch
N3 Onboarding	C1, C5, C8	Assessor must be ACTIVE in the roster before A6 passes; D7 attached to D1
Revised C7	C3, N1, register	Windows read from configuration (baseline/revised); personal-data flag unchanged

11.4 Defence of the final framework using the evidence

Claim	Evidence
The framework prevents unauthorized or out-of-scope action	Walkthrough: vendor-hosting (P1) and blackout (P2) problems were caught before testing. Tests: all 17 authorization and 7 scope cases correct; conduct rule separates 12 of 12 cases.
It is legally defensible	Legal map (Task 4) links 11 legal requirements to controls and tests; the personal-data conclusion adopts DPDP-grade controls before they become binding (about May 2027); CFAA exposure is handled by consent and out-of-scope rules.
It protects personal data in practice	Walkthrough day 9: the tester stopped at the first sight of a student's name; rule F5 rejected the unredacted screenshot; DPO was informed; the finding report passed after redaction.
It scales	Task 10: at large scale refined approval is 0.88 working days (baseline 1.69) and scope checks halve (28 → 14); standing authorization reduces continuous-scan approvals by 99.2 %.
Disclosure is timely and coordinated	Disclosure tests F1–F6 give the correct route, deadline and escalation under both clocks; the revised clock is a configuration change.
It remains easy to govern and extend	Of eight components, three are retained, four modified and one redesigned; none is replaced. The three new parts attach to the existing engagement record and register.

11.5 Acceptance check against the design criteria of Task 1

Criterion	Result	Evidence
DC1 Authorization completeness	Met	17 of 17 D1 cases correct
DC2 Scope precision	Met	7 of 7 scope cases correct, including 04:59 / 05:00 boundary
DC3 Legal traceability	Met	11 legal requirements each linked to a control and a test (Task 4.4)

Criterion	Result	Evidence
DC4 Containment	Met (design level)	Host-only network; negative checks specified; address guard 7 of 7 correct. Not yet verified on a built lab
DC5 Timeliness	Met	Amber and overdue actions in disclosure tests; revised clocks
DC6 Scalability	Met only after refinement	Refined large-scale mean approval 0.88 days; baseline 1.69 days failed
DC7 Reusability	Met	Six documents; 10 of 10 D3 cases correct
DC8 Adaptability	Met	No component replaced; three retained, four modified, one redesigned

11.6 Remaining trade-offs and limitations, and future improvements

#	Trade-off or limitation	Why it remains	Proposed future improvement
1	Standing authorization trades per-scan control for speed; a stolen or misused token could be abused for 90 days	Continuous scanning is impossible without it	Shorter tokens for sensitive systems; cryptographically signed tokens bound to tester and source IP; weekly automatic digest to the CISO
2	Shorter disclosure clocks raise the load on system owners and may cause rushed or poor fixes and many escalations	The changed requirement demands it	Owner capacity plan; service-criticality-based windows; temporary mitigations (disable feature) accepted as interim closure
3	The Board secretariat and the CISO are still human single points of failure	Signatures and risk decisions need accountable people	Deputy roster; policy-as-code to approve routine low-risk requests automatically with sampling audits
4	The scalability results come from a simulation with assumed service times, not from real measurements	No real programme data exists yet	Run a one-department pilot for one semester; replace assumptions with measured approval and fix times
5	The legal mapping depends on law that is changing (DPDP commencement, CERT-In directions) and was prepared from public sources, not legal advice	Law is outside the team's control	Quarterly review by counsel; version stamp on every legal row; add state-law and sector-regulator (for example UGC) requirements
6	Everything depends on an accurate asset register	Scope, tokens and checks all use it	Automated discovery to detect unregistered assets; owner attestation each semester

11.7 Conclusion

The UEHEF framework turns an unstructured ethical-hacking activity into a governed programme in which every test is authorized, scoped, lawful, ethical, recorded and disclosed on a clock. The walkthrough showed six practical problems, all of which were fixed and re-tested; the evaluation showed that the first design would not scale and the refined design does; and the changed requirement was met by adding three components and redesigning one, without discarding the engagement record, the register or the document library. The remaining limitations are stated openly and have concrete next steps.

Appendix A – Reproducing the evidence

All tests in this document were produced by small Python programs that contain only decision logic and no network or exploitation code: framework.py (authorization checks A1–A10, scope checks S1–S5, disclosure rules for the baseline and revised clocks), conduct.py (conduct decision rule, lab address guard, finding validator, standing-authorization check) and sim.py (scalability simulation). Running python3 conduct.py regenerates the test results and python3 sim.py regenerates the evaluation table (seed 2026 + run number, 200 runs). The figures were drawn with matplotlib.

Summary of executed checks

Suite	Cases	Passed
D1 authorization checks	17	17
Scope requests (S1–S5)	7	7
Conduct decision rule	12	12
Lab address guard	7	7
D3 finding validator	10	10
Standing authorization states	5	5
Total	58	58

Appendix B – Simulation code (sim.py, core parts)

```
"""Reproducible scalability model (seeded). Queueing simulation in WORKING HOURS (8 h/day, 5 days/week).
Processes: (A) engagement approval, (B) scope verification effort, (C) disclosure triage decision."""
import numpy as np, heapq, json
SEED = 2026
H_PER_MONTH = 8 * 22   # working hours per month
def multi_server(arrivals, service, servers):
    """FCFS multi-server queue; returns waiting+service time for each job (hours)."""
    free = [0.0] * servers
    heapq.heapify(free)
    out = []
    for a, s in zip(arrivals, service):
        t = heapq.heappop(free)
        start = max(a, t)
        heapq.heappush(free, start + s)
        out.append(start + s - a)
    return np.array(out)
def approval(scn, mode, rng, months=12):
    n = rng.poisson(scn["eng_per_month"] * months)
    arr = np.sort(rng.uniform(0, months * H_PER_MONTH, n))
    ext = rng.random(n) < scn["ext_share"]
    high = rng.random(n) < scn["high_risk_share"]
    if mode == "baseline":       # every request -> one Governance Board secretariat queue (+ vetting for externals)
        svc = rng.exponential(2.0, n) + ext * rng.exponential(4.0, n)
        t = multi_server(arr, svc, 1)
        steps = np.where(ext, 10, 7)
    else:                        # tiered: low-risk -> dept security leads (parallel); high-risk / external -> Board
        lowq = ~(high | ext)
        t = np.zeros(n)
        svc_low = rng.exponential(0.75, lowq.sum())
        t[lowq] = multi_server(arr[lowq], svc_low, scn["dept_leads"])
        hi = ~lowq
        svc_hi = rng.exponential(2.0, hi.sum()) + ext[hi] * rng.exponential(2.0, hi.sum())  # vetting pre-done by roster
        t[hi] = multi_server(arr[hi], svc_hi, 1)
        steps = np.where(lowq, 5, np.where(ext, 9, 8))
    # fixed human latency per request (collecting signatures) added identically to both modes: 4 working hours
    t = t + 4.0
    return dict(n=int(n), mean_days=float(t.mean() / 8), p90_days=float(np.percentile(t, 90) / 8),
                steps=float(steps.mean()), approved_in_5d=float((t <= 40).mean() * 100))
def scope_effort(scn, mode):
    """Checklist checks needed per engagement (analytic)."""
    k = scn["sys_per_eng"]
    if mode == "baseline":       # 6 manual checks per target system + 4 engagement-level checks
        return 6 * k + 4
    return 6 + 1 * k + 4         # 6 register-linked checks once + 1 exception check per system + 4 engagement-level
def coverage(scn, mode, rng, ap):
    """% of in-scope systems with an approved engagement inside a quarter (tester-capacity bound)."""
    per_q = ap["n"] / 4.0
    cap_testers = scn["testers"] * 1.5          # each tester completes ~1.5 engagements / quarter
    ok_frac = ap["approved_in_5d"] / 100        # engagements approved quickly enough to start in window
    done = min(per_q * ok_frac, cap_testers)
    return float(min(100.0, done * scn["sys_per_eng"] / scn["systems"] * 100))
def disclosure_triage(scn, mode, rng, months=12):
    n = rng.poisson(scn["findings_per_month"] * months)
    arr = np.sort(rng.uniform(0, months * H_PER_MONTH, n))
    sev = rng.choice(["Critical", "High", "Medium", "Low"], n, p=[.05, .15, .40, .40])
    if mode == "baseline":       # Board decides every finding
        svc = rng.exponential(0.75, n)
        t = multi_server(arr, svc, 1)
    else:                        # severity routed: C/H -> Board, M/L -> disclosure officer (rule-based, 2 officers)
        ch = np.isin(sev, ["Critical", "High"])
        t = np.zeros(n)
        t[ch] = multi_server(arr[ch], rng.exponential(0.75, ch.sum()), 1)
        t[~ch] = multi_server(arr[~ch], rng.exponential(0.25, (~ch).sum()), 2)
```

```
    t = t + 2.0                 # fixed: validation + owner notification
    crit = np.isin(sev, ["Critical"])
    return dict(n=int(n), mean_days=float(t.mean() / 8), p90_days=float(np.percentile(t, 90) / 8),
                crit_mean_days=float(t[crit].mean() / 8) if crit.any() else float("nan"))
SCEN = {
 "Small (1 department)": dict(systems=5, testers=3, eng_per_month=3, ext_share=0.0, high_risk_share=0.3,
                              sys_per_eng=2, dept_leads=1, findings_per_month=6),
 "Large (whole university + external)": dict(systems=400, testers=40, eng_per_month=30, ext_share=0.4, high_risk_share=0.3,
                              sys_per_eng=4, dept_leads=8, findings_per_month=120),
}
def run(runs=200):
    res = {}
    for name, scn in SCEN.items():
        for mode in ("baseline", "refined"):
            acc = []
            for r in range(runs):
                rng = np.random.default_rng(SEED + r)
                ap = approval(scn, mode, rng)
                cov = coverage(scn, mode, rng, ap)
                dt_ = disclosure_triage(scn, mode, rng)
                acc.append((ap["mean_days"], ap["p90_days"], ap["steps"], ap["approved_in_5d"], cov,
                            dt_["mean_days"], dt_["crit_mean_days"]))
            a = np.nanmean(np.array(acc), axis=0)
            res[f"{name}|{mode}"] = dict(
                approval_mean_days=round(a[0], 2), approval_p90_days=round(a[1], 2), steps=round(a[2], 1),
                approved_within_5d=round(a[3], 1), coverage_pct=round(a[4], 1),
                scope_checks=scope_effort(scn, mode), disclosure_mean_days=round(a[5], 2),
                disclosure_crit_days=round(a[6], 2))
    return res
if __name__ == "__main__":
    r = run()
    json.dump(r, open("sim.json", "w"), indent=1)
    for k, v in r.items():
        print(k, v)
```

References and sources

All web pages were opened on 1 November 2026. Secondary legal summaries were used only for dates and to cross-check statutory figures and should be verified against the official Gazette and statute text before any legal reliance.

- Anthropic – Claude (claude.com): home page and links to security, trust centre, privacy and responsible-disclosure pages. https://claude.com/
- Anthropic – Responsible Disclosure Policy (scope, rules for researchers, safe harbour, three-business-day acknowledgement). https://www.anthropic.com/responsible-disclosure-policy
- Anthropic – Coordinated Vulnerability Disclosure (90-day deadline, 14-day extension, 7-day exploited-bug target, 30-day escalation, 45-day detail embargo after patch; as of 6 March 2026). https://www.anthropic.com/coordinated-vulnerability-disclosure
- Information Technology Act, 2000 – text (PRS India copy). https://PRSINDIA.org/files/bills_acts/bills_parliament/2021/IT Act, 2000.pdf ; overview of offences and penalties: https://www.gktoday.in/it-act-2000-key-provisions/
- Digital Personal Data Protection Act, 2023 and DPDP Rules, 2025 – implementation timeline and penalties (secondary summary). https://www.dpdpa.com/blogs/DPDPA_Implementation_Timeline.html ; Khaitan & Co. ERGO note of 15 November 2025 (search result); Hogan Lovells note on the Act being brought into force (search result).
- CERT-In Directions of 28 April 2022 (6-hour incident reporting) – Trilegal and other law-firm notes (search results). https://trilegal.com/knowledge-repository/2022-cert-in-directions-on-reporting-cyber-incidents/
- Computer Fraud and Abuse Act, 18 U.S.C. §1030, and the U.S. Department of Justice charging policy of May 2022 – Jones Day: "Department of Justice Significantly Revises Policy on Charging CFAA Violations". https://www.jonesday.com/en/insights/2022/06/department-of-justice-significantly-revises-policy-on-charging-cfaa-violations
- Penalty figures for IT Act sections 66, 66B–66F, 70, 72, 72A and CFAA subsection maxima are taken from the statute texts as summarised in the sources above and from standard references; they should be re-checked with counsel.